Desarrollo de una Guía de buenas prácticas para la prevención de incidentes de seguridad sobre entorno Windows en Pequeñas y Medianas empresas

EUGENIO DANIEL DELUCA

Tesis de Grado en Licenciatura en Sistemas

Director: Lic. Martín Correa

Universidad Católica de La Plata

Facultad de Ciencias Exactas e Ingeniería

La Plata - [Fecha Entrega: diciembre de 2019]

Desarrollo de una Guía de buenas prácticas para la prevención de incidentes de seguridad sobre entorno Windows en Pequeñas y Medianas empresas

EUGENIO DANIEL DELUCA

Tesis de Grado en Licenciatura en Sistemas

Director: Lic. Martín Correa

Universidad Católica de La Plata

Facultad de Ciencias Exactas e Ingeniería

La Plata - [Fecha Entrega: diciembre de 2019

Índice

Dedicatoria VI
Agradecimientos VII
Resumen VIII
Summary IX
INTRODUCCIÓN 1
Capítulo I – DEFINICIONES PRELIMINARES 3
Alcance del trabajo y limitaciones: 3
Planteo del problema 4
Objetivos (generales y específicos) 4
Objetivos específicos: 4
Capítulo II – MARCO TEÓRICO 5
Conceptos Básicos: 5
Amenazas a las que se deben enfrentar 7
Clasificación de software malicioso: 7
Definición de Malware: 7
Técnicas de ataque más conocidas: 9
Formas de trabajo bajo Windows: 11
En resumen - Grupo de Trabajo Vs Dominio: 11
Capítulo III - SEGURIDAD LÓGICA 12
Concepto de Principio del mínimo privilegio: 12
Usuarios dentro del Sistema Operativo: 13
Cuentas de Usuarios: 13
Renombre de nuevo cuenta de huésped/usuario estándar: 14
Permisos en archivos y carpetas: 14
UAC (Control de Cuenta de Usuarios): 15
Editor de directivas de grupo local: 16
Métodos de Autenticación de Usuarios 19
Contraseñas: 19
Certificados digitales: 19
Identificación biométrica: 20
Autenticación multifactor: 20
Detalles de las Contraseñas: 20

Servicios 23
Administración de autenticación de Xbox Live: 24
Administrador de conexiones automáticas de acceso remoto: 24
Administrador de mapas descargados: 24
Programas que utilizan los usuarios: 24
Antivirus 37
Firewalls 39
Limitaciones de los firewalls a tener en cuenta: 40
IDS e IPS 41
Las funciones de un IDS: 41
Dispositivos de conexión de Redes 42
Hubs: 42
Switch: 43
Router: 44
Concepto General de Seguridad Física: 45
Amenazas naturales: 45
Amenazas del Entorno: 46
Amenazas Humanas 48
Planes de contingencia 52
Tipo de seguridad Completa: 55
Tipo de seguridad Diferencial: 55
Tipo de copia Incremental: 55
Capítulo V - Desarrollo 57
Casos prácticos 58
Actividad Comercial 58
En tipos de PyMEs Micro: 60
Alternativa Baja: 60
Alternativa Alta: 63
En tipos de PyMEs Pequeña: 64
Alternativa Baja: 64
Alternativa Alta: 65
En tipos de PyMEs Mediana - Tramo I y Tramo II: 67

Alternativa Baja: 67
Alternativa Alta 69
Capítulo VI - Conclusiones 71
Capítulo VII - Líneas de Trabajo a futuro 73
Anexo A 74
Cuentas de usuario: 74
Anexo B 77
Permisos a usuarios - Carpetas - Archivos - Recursos Compartidos: 77
Anexo C 80
Directivas de seguridad Locales: 80
Anexo D 82
Servicios: 82
Anexo E 89
Ejecución de programas como usuario Administrador/Otro Usuario: 89
Capítulo VIII - Bibliografía 94

Dedicatoria

Este trabajo está dedicado a mis padres y mi esposa que siempre me brindaron su apoyo incondicional para con mis estudios.

También está dedicado a aquellas personas que busquen conocimientos en pos de mejorar su situación actual con respecto a la seguridad en su organización

Agradecimientos

En primer lugar, mis agradecimientos están dirigidos a Martin Correa quien fue mi guía en este trabajo y en mi carrera universitaria, a la Universidad Católica por el hecho de haberme inculcado la base de mis estudios para crecer personal y profesionalmente y, en tercer lugar, a aquellos portales de información como es el caso del Foro de UnderC0de y algunos usuarios específicos de esta comunidad a los cuales puede recurrir para un mejor entendimiento del problema y posibles soluciones.

Resumen

Con la introducción de las Pequeñas y Medianas Empresas (PyMEs) en el mundo digital, surge la necesidad de reforzar la seguridad de los datos de las empresas y sus miembros para garantizar su privacidad. "PyME" es el acrónimo de pequeña y mediana empresa. Éstas tienen ciertas características que las definen como tal. Una PyME se define a razón del volumen de ingresos, valor de patrimonio y número de trabajadores, siendo prefijados por los estados o regiones. En Argentina se define a las PyMEs por las ventas anuales y según el tipo de empresa. Una empresa que tiene un volumen de ingresos fijo acarrea el problema de que no pueda formar un departamento de sistemas bien constituido. Esta es un área interna de la organización donde el personal esté capacitado para enfrentar incidentes informáticos, o pueda capacitar correctamente a sus empleados para que sepan cómo prevenir ataques con simples prácticas. Otro factor es algo muy común de encontrar es el pensamiento despreocupado en la gerencia: “Mi empresa no tiene nada que ocultar”, o, “Mi empresa no puede ser objetivo de ningún hacker”. Estas y otras frases similares que pueden ser inocentes por desconocimiento, generando un riesgo muy grande. La falta de prevención a los ataques ya sea por no tener conocimientos suficientes, el capital para poder capacitar a los involucrados de la organización sean usuarios finales o técnicos en el área y tener un pensamiento desentendido del tema, hacen que estos factores se vuelvan altamente riesgosos para la organización. Este trabajo inicia con las problemáticas mencionadas anteriormente en una PyME frente a las amenazas Informáticas. También consta de una sección donde se enmarca el campo de estudio y las limitaciones de dicho trabajo. Se definen algunos conceptos básicos que se tienen en cuenta a la hora de analizar las problemáticas y sus respectivas soluciones. La siguiente sección da lugar a un proceso en el cual se identifican los posibles riesgos, se evalúan qué alternativas se pueden mitigar o solucionar por completo y se realiza una selección de la alternativa más adecuada para aplicarla en cada circunstancia.

Summary

With the introduction of SMEs in the digital world, the need arises to reinforce the security of the data of the companies and their members to guarantee their privacity. 'SEMEs' is the acronym for small and medium enterprises. These have characteristics that define them as such. An SME is defined based on the volume of income, value of assets and number of workers, being prefixed by states or regions. In Argentina, SMEs are defined by annual sales and according to the type of company.

A company that has a fixed volume of income carries the problem of not being able to form a well-established system departament. That is an internal area of the organization where the worker is trained to face computer incidents, or can properly train its employees so they know how to prevent attacks with simple practices.

Another very common factor to find is carefree thinking in management: "My company has nothing to hide", or, "My company cannot be the target or any hacker". These and other similar phrases that may be innocent due to ignorance, which creates a very large risk.

The lock of prevention of attacks either because they don't have enough knowledge, the capital to be able to train those involved in the area and have a disregarded thinking about the subject, make these factors become highly risky for the organization.

This work begins with the problem mentioned above in an SME against computer threats. It also consists of a section where the field of study and the limitations of this work are framed. Some basic concepts that are taken into account when analyzing the problems and their respective solutions are defined. The following section gives rise to a process in which the possible risks are identified, which alternatives can be mitigated or completely solved are evaluated and a selection of the most appropriate alternative is applied to apply it in each circumstance.

INTRODUCCIÓN

La falta de información sobre cómo afrontar las amenazas Informáticas hace que una PyME sea vulnerable ante dichas amenazas. Esto le puede significar grandes pérdidas, ya sean monetarias y/o de información muy valiosa tanto de su empresa como de cada uno de sus trabajadores. Varios reportes de distintas Firmas de antivirus indican que cuatro de cada diez PyMEs son víctimas de diversos ataques, y aun sobreviviendo a dichos ataques, se revela que el 60 % de éstas luego de un plazo aproximado de seis meses desaparece.

Es importante destacar que la seguridad Informática, como ocurre en la realidad, no puede garantizarse un 100% de cobertura como en otros libros e informes se ha mencionado.

Eugene H. Spafford - "El único sistema verdaderamente seguro es aquel que está apagado, encerrado en un bloque de hormigón y sellado en una habitación recubierta de plomo con guardias armados… y aun así tengo mis dudas."[(1)]

Este trabajo está enfocado aquellas PyMEs que utilicen como Sistema Operativo Microsoft Windows, sistema el cual se cree que es muy inseguro en cualquier ámbito de trabajo.

Curiosamente a nivel mundial es el Sistema Operativo más utilizado, a continuación, para dejar ilustrado este punto, se genera una estadística de los sistemas operativos más usados, comparándolos entre sí en la fecha de 12/2017 hasta el 08/2019, dicha estadística refleja la comparación en este caso de sistemas operativos Windows con respecto a Linux y Mac. La estadística se realizó mediante una Página web la cual será adjuntada en la sección de Bibliografía.

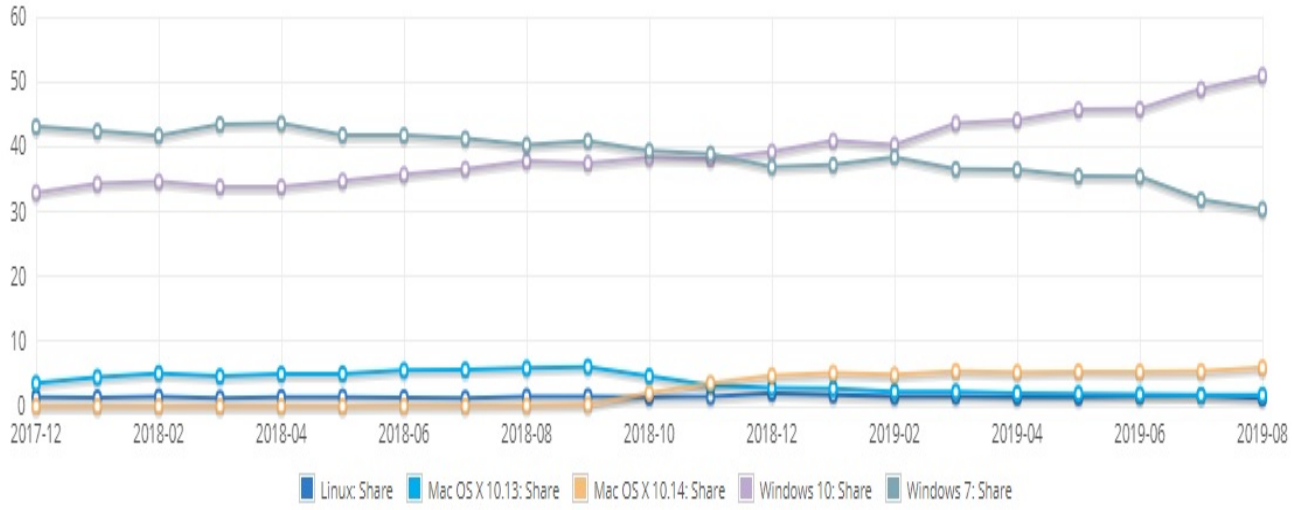

Fig. 1 – Imagen de Estadística de los Sistemas Operativos más usados desde fines de 2017 a agosto 2019

El hecho es que a primera vista puede ser que parezca inseguro, pero si analizamos un poco la situación, siendo un producto pago, posee un entorno cómodo, simple, flexible y estéticamente más agradable a la visa para el trabajo de cualquier tipo de usuario. Pero a su vez hace que sea objetivo sistemático por los atacantes. Sumando a esta situación, se encuentra el hecho de que la mayoría de las personas dejan una configuración por defecto y sin realizar ningún esfuerzo por mitigar las distintas amenazas.

Capítulo I – DEFINICIONES PRELIMINARES

Alcance del trabajo y limitaciones:

Esta investigación definirá los conceptos básicos y esenciales de seguridad a aplicar en una organización como lo es una PyME para poder hacer frente a los problemas de hoy en día. El estudio está enfocado a Microsoft Windows que es una familia de distribuciones de software para varios dispositivos, comúnmente se le denomina Windows o MS Windows, no son sistemas operativos, sino que contienen uno (tradicionalmente MS-DOS, o el más actual cuyo núcleo es Windows NT) junto con una amplia variedad de software. Este estudio no abarca en su totalidad las versiones de servidores conocidos comúnmente como Windows Server, sino que se hará una introducción algunos temas puntuales. También se verán algunas configuraciones de redes como lo son Configuración de seguridad de switches, routers. Conceptos básicos de Seguridad como lo es CIA (Confidencialidad, Integridad y Disponibilidad) y las diferencias entre autenticación y autenticidad. Con el fin de, unido a los conceptos analizados y estudiados, relacionarlo con las experiencias que se enfrentan cada día y con todo el material, generar un documento donde se den algunas ideas para que una PyME, es decir el personal de sistemas o por qué no, un tercero que aplique estas pautas. Otra razón por la cual se genera este documento es para facilitar el estudio a aquellos interesados en el tema. Al ser un tema tan amplio y complejo, la intención es dejar plasmada una base para que se pueda seguir desarrollando con el paso del tiempo. El material aquí presentado también es una herramienta para concientizar a distintos niveles, sean estos organizaciones, estudiantes o personas afines preocupados por la seguridad en las PyMEs.

Planteo del problema

Problema: Se puede observar que existe un descuido de sus activos de información por parte de las PyMEs en las versiones de Windows comprometiendo así la seguridad de los mismos. Es común que en una PyME ya sea por pocos recursos o no poseer conocimientos, instalación de equipos con configuraciones por defecto, permiso total a todos los usuarios, o lo que es peor, que estén usando la cuenta de Administrador, no realizar copias de seguridad (backup) de la información crítica, o por el contrario, realizarlo pero dejarlo en el mismo dispositivo, también la poca capacitación a los mismos usuarios de la empresa genera la facilidad para los atacantes y así se pueden enumerar un sin fin de problemáticas o "puertas" que se dejan abiertas para un ataque externo.

Objetivos (generales y específicos)

- Asegurar la infraestructura de la PyME para que no esté desprotegida ante vulnerabilidades que puedan causar un incidente tanto dentro de la misma PyME como para internet.

  Objetivos específicos:

  1. Analizar tanto el hardware como el software vulnerabilidades conocidas.
  2. Diagnosticar dichas vulnerabilidades.
  3. Definir los riesgos de esas vulnerabilidades.
  4. Brindar una solución aceptable para prevenir esos riesgos.
- Definir un conjunto de buenas prácticas a seguir para poder hacer frente a distintos incidentes de seguridad y así evitar los daños generados por los mismos.

Objetivos específicos:

1. Definir las vulnerabilidades que ponen en peligro la seguridad de la información
2. Seleccionar y definir procedimientos y medidas para salvaguardar las vulnerabilidades identificadas
3. Comprobar y verificar las medidas y procedimientos aplicados.

Capítulo II – MARCO TEÓRICO

Dado que este trabajo tendrá una perspectiva central en el desarrollo de una alternativa para las PyMEs puedan enfrentar las diversas amenazas Informáticas que hoy día representan un gran problema, será necesario plantear algunos conceptos que sirvan de base para afrontar dichas amenazas, como el concepto de CIA (Confidencialidad, Integridad y Disponibilidad), así como también entender el concepto de Riesgo en el ámbito informático, la gestión de seguridad en el tiempo y conceptos generales de redes.

También se estudiarán conceptos de Políticas, planes y procedimientos de seguridad y la importancia del factor humano. Luego de una extensa búsqueda, estudio y entendimiento de estos y otros temas más, sumado a la experiencia aportada por otros colegas y algunas experiencias propias.

Conceptos Básicos:

En primer lugar, se debe poseer una base en común de conocimientos para comenzar a transitar por el camino de proteger una organización frente a diversas amenazas.

Es oportuno indicar el concepto de Seguridad de la información. Hay muchas definiciones, pero la más completa es la siguiente definición: “Preservación de confidencialidad, integración y disponibilidad de la información: además, también puede involucrar otras propiedades como autenticidad, responsabilidad, no repudiación y confiabilidad.”

La definición de Seguridad será entonces: La seguridad consta de medidas y controles que aseguran la confidencialidad, integridad y disponibilidad de los activos de información.

Esto lleva a definir “Activos de Información” en el marco de la seguridad Informática como aquellos recursos de información o relacionados a éste, que son necesarios para el correcto funcionamiento de la organización.

A su vez, se debe tener en claro los conceptos que conforman la CIA, comenzando por la Confidencialidad que se define como la información que debe ser accesible únicamente a las personas autorizadas.

El siguiente concepto es el de Integridad que es la característica que protege sobre la modificación o destrucción no autorizada de la información. Es decir que la información debe mantenerse “completa” de manera que sea fiable dicha información.

Y el concepto de Disponibilidad se define como la característica que garantiza que la información debe ser accesible en todo momento.

Hay dos definiciones que se interpreta de la misma forma, pero son distintas estas son Autorización y Autenticación. La primera refiere a lo que un usuario determinado puede o no realizar (generalmente esto se ve plasmado en los perfiles). Y la Autenticación refiere a verificar que el usuario es quien dice ser.

En este documento se ve la necesidad de aclarar los siguientes puntos:

Que es una Vulnerabilidad: “Es una debilidad en el sistema, aplicación o infraestructura, control o diseño de flujo que puede ser explotada para violar la integridad del sistema” - Entonces se puede indicar que es una situación concreta en los sistemas que puede facilitar a un usuario no autorizado a la realización de ataques a la red de la organización.

Este concepto difiere de Riesgo que es la Probabilidad de ocurrencia de un tipo de ataque hacia la red de la organización en consecuencia de su grado de exposición o vulnerabilidades existentes. Riesgo **cero** no existe. Y de una Amenaza se puede definir como la indicación de un potencial evento no deseado.

Es importante destacar que se distinguen dos grandes grupos en lo que refiere a ataques informáticos.

El primer grupo se lo puede catalogar como Ataques Pasivos. Estos se limitan a registrar el uso de los recursos y/o acceder a la información guardada o transmitida por el sistema. Por citar algunos ejemplos de este tipo de ataques podrían ser el análisis de tráfico o el sniffing.

El otro grupo se catalogan como Ataques Activos, estos producen cambios en la información y en la situación de los recursos del sistema. Algunos ejemplos de estos lo son la suplantación de identidad, modificación de la información, DDoS/dos.

Amenazas a las que se deben enfrentar

Clasificación de software malicioso:

Definición de Malware:

Aplica a todo programa o código malicioso que representa un riesgo para un sistema informático. Existen diversos tipos de malware, esto depende de qué rol cumpla.

- Virus:

  Este tipo de software tiene la característica que infecta a otros programas con la intención de modificarlos o dañarlos. Los virus informáticos tienen, básicamente, la función de propagarse a través de un software, no se replican a sí mismos porque no tienen esa facultad

- Worm:

  Los worms tienen la facultad de propagarse por los dispositivos, pero sin la ayuda de la intervención humana, esto hace que un dispositivo podría enviar cientos o miles de copias de sí mismo.

- Troyano:

  Este software aparenta ser inofensivo para el usuario, pero cuando se ejecuta, en segundo plano está generando un acceso remoto al atacante generando así una puerta trasera o conocida como backdoor (*).

- (*) Backdoor:

  Dentro del código de programación de algún software, es una secuencia que evita la autenticación de los mecanismos de seguridad habituales para acceder al sistema. Este mecanismo puede ser utilizado con fines maliciosos o bien porque han sido diseñados con la intención de tener una entrada secreta.

- Keylogger:

  Este software se encarga de registrar las pulsaciones del teclado y luego los guarda en un log o se envía por internet. Dejando así expuesta las contraseñas u otros datos importantes.

- Spyware:

  Este malware se encarga de recolectar información privada de un dispositivo y luego se transmite sin conocimiento o consentimiento del propietario del dispositivo. Se auto instala en el sistema operativo del dispositivo, esto implica que se inicia junto al inicio del ordenador utilizando los recursos del mismo como si fuera un parásito.

- Ransomware:

  Tipo de malware que impide a los usuarios acceder a su sistema o a sus archivos personales y que exige el pago de un rescate, generalmente en bitcoins, para poder acceder nuevamente a ellos, usualmente el sistema o los archivos infectados son fuertemente cifrados.

Técnicas de ataque más conocidas:

- DDoS:

  Es importante hacer una clara distinción entre DoS (Denegación de servicio) el cual consta en generar una cantidad masiva de peticiones a un servidor desde un dispositivo, provocando así una sobrecarga del mismo y, por consiguiente, la alteración del servicio a los usuarios que sí son legítimos. DDoS (Denegación de Servicio Distribuido) es más complejo ya que este ataque se produce de varios dispositivos al mismo tiempo con peticiones masivas a un único servidor.

- Phishing:

  Es un método que los ciber-delincuentesncuentes utilizan para engañar y conseguir que la víctima revele información personal, como contraseñas no datos de tarjetas de crédito y números de cuentas bancarias. Lo hacen mediante el envío de correos electrónicos fraudulentos o dirigiéndose a un sitio web falso.

- Ataque fuerza bruta:

  Es el método utilizado frecuentemente para averiguar una contraseña probando todas las combinaciones posibles hasta dar con la correcta.

- Spoofing:

  Término que se entiende por el uso de técnicas de suplantación de identidad generalmente con usos maliciosos, es decir, un atacante falsea el origen de los paquetes haciendo que la víctima piense que estos son de un host de confianza o autorizado para evitar la víctima lo detecte. Se menciona en varias fuentes de información que para poder realizar un TCP Spoofing exitoso, previamente se deben realizar los siguientes pasos: Falsear la MAC (ARP Spoofing) luego Falsear la IP (IP-Spoofing) y por último Falsear la conexión TCP (TCP Spoofing). Ejemplos típicos de tipo de ataques que se usan con esta técnica son Man In the Middle y DoS.

- Ingeniería social:

  Es la metodología que permite obtener información confidencial a través de la manipulación de usuarios legítimos. Usualmente tiene intervención directa el atacante con la víctima (ejemplo: llamado telefónico). Dando como resultado, acceso o privilegios en sistemas de información que le permita realizar algún acto que perjudique o exponga la persona u organismo comprometido a riesgo o abusos. Los tipos de ataque que son usados bajo esta metodología es por ejemplo el Phishing o Carnada (El cibercriminal puede dejar un dispositivo, como una memoria USB, infectado con software malicioso a la vista en un espacio público. Alguien recogerá ese dispositivo y lo conectará a su equipo para ver qué contiene. En ese momento, el software malicioso se introducirá en el equipo.).

- BotNet:

  Es un conjunto de dispositivos comprometidos y controlados remotamente por un atacante. Generalmente los atacantes crean un BotNet usando algún malware que infecta una gran cantidad de dispositivos, éstos se denominan bots o zombis que se ejecutan de manera autónoma y automática. Así puede un atacante realizar distintos tipos de ataque, el más común es DDOS (Ataque de denegación de servicio Distribuido).

- Man In the Middle:

  Denominado también como Hombre en el medio. Este ataque comúnmente se requiere de dos víctimas y un atacante, éste adquiere la capacidad de leer, insertar y modificar a voluntad los mensajes que se transmiten entre las víctimas. El atacante debe ser capaz de observar e interceptar mensajes entre las dos víctimas y procurar que ninguna de las víctimas conozca que el enlace entre ellos ha sido violado.

Formas de trabajo bajo Windows:

Existen dos alternativas como formas de trabajo. La primera que en algunas empresas se usa es el Grupo de Trabajo, el cual los equipos tienen la misma importancia y cooperan entre sí compartiendo diversos recursos (impresoras, archivos, etc.). La otra forma de trabajo es bajo Dominio, la diferencia con la anterior forma es que los equipos que forman parte de una red, éstas confían la administración de usuarios y privilegios a un equipo denominado comúnmente como Servidor.

En resumen - Grupo de Trabajo Vs Dominio:

Grupo de trabajo: • Todos los pc pertenecen al mismo nivel • Cada equipo posee N cuentas de usuario • Todos los equipos deben estar en la misma red o subred • Normalmente se utiliza en entornos con 10 a 20 equipos
Dominio: • Posee una Jerarquía donde el equipo que administra los usuarios y otros temas es el Servidor • Si se dispone de una cuenta de usuario dentro del dominio, puede ingresar independientemente de que equipo utilice. • Existe la posibilidad de que los equipos estén en distintas redes. • La cantidad de equipos es superior a las que podrían gestionar aquellos que utilizan grupo de trabajo (Se hablan de unos cientos o miles de equipos)

Capítulo III - SEGURIDAD LÓGICA

Concepto de Principio del mínimo privilegio:

La correcta asignación de permisos a usuarios y aplicaciones debe formar parte integral de toda política de seguridad. No todo el mundo debe contar con los mismos privilegios de acceso sobre todos los objetos. El principio del mínimo privilegio constituye uno de los conceptos fundamentales de la seguridad de la información:

Todo usuario o programa debe tener asignados los mínimos privilegios necesarios de manera que pueda seguir realizando su función.

La política de seguridad de la empresa debe detallar los criterios que definan el acceso, basados en la identidad de los usuarios, su puesto, sus funciones, su ubicación, la hora, etc.

Este concepto se encuentra íntimamente relacionado con el de separación de obligaciones y responsabilidades: las tareas más sensibles no deberían ser realizadas por un único usuario, sino que se deberían asignar a diferentes usuarios de manera que ninguno solo sea capaz de llevarlas a cabo.

Así las oportunidades de realizar actividades maliciosas, fraudulentas o no autorizadas se ven limitadas y así es factible aumentar la capacidad de su detección. Si uno de ellos es engañado o deliberadamente desea causar daño, el alcance de sus acciones se verá drásticamente limitado y no pasará desapercibido.

Es muy frecuente encontrar en cualquier tipo de empresa, que por desconocimiento o por descuido, los usuarios tengan mayores privilegios de lo que les corresponde. También existen usuarios que utilizan cuentas administrativas, es decir, cuentas con máximos privilegios, para desarrollar su trabajo diario. Es habitual escuchar la excusa de que, si tal programa o usuario no trabaja como usuario Administrador, las cosas no funcionan.

Si bien es posible que requiera más privilegios que un usuario normal para ciertas tareas, lo que es seguro es que no necesita ser Administrador todo el tiempo.

Cuando se den de alta usuarios, deben ser usuarios con el tipo de cuenta “Limitada”.

En resumen, se determina que nunca se debe utilizar una cuenta de Administrador o miembro del grupo Administradores para tareas cotidianas. Se debe utilizar siempre un usuario normal, tal vez con más privilegios que otros usuarios, pero solamente allí donde sea absolutamente necesario.

Para las actividades más peligrosas, como navegar por Internet o leer el correo, se recomienda utilizar una cuenta con los mínimos privilegios posibles para reducir al mínimo los riesgos que pueden tener aparejados.
Si en algún momento se necesita ejecutar algún programa como Administrador, se debe cerrar la sesión e iniciar una nueva sesión como administrador. De esta forma tendrá que cerrar todas las aplicaciones que tenía abiertas.

Usuarios dentro del Sistema Operativo:

Los usuarios son una parte fundamental en este mundo, sin ellos, las tareas que la PyME desea realizar, no podría ser. Hay que tener siempre presente el concepto de mínimo privilegio como se comentó anteriormente.

Cuentas de Usuarios:

Un detalle fundamental es que las cuentas que no están siendo utilizadas, deben borrarse o desactivarse (si se requiere un historial o bien así la empresa lo tenga definido). Es importante destacar que debería deshabilitarse o utilizarse en casos específicos la cuenta de Administrador, sin embargo, es posible que se renombre la cuenta de administrador.
Por increíble que parezca para algunos lectores, la cuenta de Administrador usualmente está habilitada para su uso por diversos motivos.
Sin embargo, conocer el nombre de una cuenta en una máquina puede ser información valiosa a un ataque y el nombre “administrador” u “administrator” es excelente y el primer objetivo de cualquier atacante. En un intento para ocultar la cuenta, las buenas prácticas recomiendan renombrar la cuenta de forma tal que el administrador o encargado de sistemas de la empresa tenga conocimiento, pero el nuevo nombre no debe hacer referencia a algo similar a administrador, por ejemplo, root/supervisor son nombres que no se utilizarían en principio.
Atención: Si se nombra de nuevo la cuenta, el identificador (SID) de seguridad anónimo/nombre la traducción también debe estar deshabilitada.
Esto impide que el atacante intente localizar la cuenta nombrada de nuevo por su SID.
Adicionalmente algo que es conveniente realizar, es el desactivar el modo de inicio de sesión con pantalla de bienvenida, ya que informa a cualquier persona con acceso físico al equipo acerca de los nombres de los usuarios del equipo

Una vez sea desactivado en adelante aparecerá una ventana pidiendo las credenciales del usuario. Para que no aparezca el nombre del último usuario que inició sesión en el equipo, deberíamos utilizar las directivas de seguridad local como se describe qué pasos se deben seguir en el Ver **Anexo "A"** con el título "Cuentas de Usuario".

Renombre de nuevo cuenta de huésped/usuario estándar:

Similar a la cuenta de administrador, la cuenta de huésped se debe nombrar de nuevo aún si se inhabilita, un ejemplo que puede aplicarse es que en nuestra empresa se despide a "Sergio", el cual tiene su cuenta de usuario, se podría inhabilitar dicha cuenta y además renombrarlo para asegurarnos que "Sergio" no pueda ingresar. La cuenta estándar de un usuario es menor objetivo que la cuenta de administrador, pero no por ello significa que no se intente acceder por este tipo de cuentas. Ver **Anexo "A"** con el título "Cuentas de Usuario"

Permisos en archivos y carpetas:

En un sistema Microsoft Windows se pueden dar permisos o denegarlos a los distintos usuarios con respecto a las carpetas, archivos de distintos tipos, etc. Aquí se define que un usuario pueda modificar, leer y ejecutar, leer (la diferencia con el anterior que solo leerá el archivo, pero no lo ejecutara y escritura. También existe la opción de Control total, dando acceso o denegando la lista anteriormente mencionada. Esta facilidad que nos brinda el sistema operativo, nos da la libertad por ejemplo de formar un grupo de usuarios e indicar si pueden realizar tales procesos o denegarles o bien hacer diferentes matices. Hay ocasiones donde el usuario sólo debe poder el leer el archivo y los demás permisos no los requiera. Para visualizar cómo debería realizar el paso a paso, ver **Anexo "B"** con el título "Permisos a usuarios - Carpetas - Archivos - Recursos Compartidos"
Hay que considerar que se ve la necesidad de configurar la visualización de archivos ocultos ya que la mayoría de los códigos maliciosos se esconden en el sistema con este tipo de atributos. Además, se deberá configurar la visualización de las extensiones de archivos para poder identificar las extensiones de los archivos descargados y no ser víctimas de técnicas como la doble extensión.

Un ejemplo muy habitual es que un atacante envía por correo a su víctima una “imagen” con un nombre similar: Imagen.jpg.exe

La víctima al recibirlo, y querer ver qué imagen le mandaron, y al no tener la posibilidad de ver las extensiones de los archivos, no se da cuenta de que está ejecutando una amenaza y así puede infectarse o caer en alguna trampa. para verificar cómo ver carpetas y archivos ocultos y sus respectivas extensiones. Este proceso se puede aplicar también a los recursos compartidos como impresoras y carpetas para restringir el acceso a personas que no deben tener acceso a ellos.

UAC (Control de Cuenta de Usuarios):

Es una función de seguridad que ayuda a evitar cambios no autorizados en el sistema operativo y puedan afectar a la seguridad o a la configuración de otras personas que usen un mismo equipo. Por estos motivos es conveniente habilitar dicha función, existen cuatro niveles con diferentes opciones.

- El nivel más bajo (no notificarme nunca), significa que se desactiva esta capa de función, y así no se notifica y dejará paso libre a la ejecución de aplicaciones.
- El siguiente nivel realiza la acción cuando una aplicación intenta cambiar la configuración de Windows, generalmente se selecciona esta opción si tarda mucho tiempo en atenuarse la pantalla.
- El nivel tres es recomendado usarlo en equipos en los cuales se usan aplicaciones que resultan familiares para el usuario y se visitan sitios webs recurrentes o conocidos.
- El nivel cuatro (notificarme siempre) se utiliza si se detectan cambios en la configuración de Windows o instalar aplicaciones nuevas o acceder a webs desconocidas, esta opción pedirá siempre para cualquier ejecución de programas, navegación, etc. Credenciales de Administrador o grupo de Administradores.

Editor de directivas de grupo local:

Conocido también como GPOs (Group Policy Object), es una función que nos permite establecer controles, permisos, bloqueos y otras tareas bien sea al usuario local o a un grupo de usuarios cuando nos encontramos dentro de un dominio. Para ver cómo acceder a ellas, ver el paso a paso en el **Anexo "C"** con el título "Directivas de seguridad Locales".

Al abrirlo se puede visualizar que se divide en dos grandes grupos

- Configuración del equipo: Esta opción nos permite realizar ajustes de la propia máquina local
- Configuración del usuario: Esta opción nos permite realizar los ajustes para el usuario que va a utilizar la máquina

A su vez estas categorías están divididas en tres categorías más

- Configuración de software: Nos proporciona control sobre el software instalado en la máquina local.
- Configuración de Windows: Esta ficha hay que prestarle mucha atención ya que si se aplica de forma incorrecta puede afectar el rendimiento del sistema en su totalidad.

Según donde se ingrese habrá algunas opciones que difieren.

- En Configuración de equipos se visualizan las opciones Directivas de resolución de nombres, opción para agregar/quitar scripts de inicio y apagado del equipo, Impresoras implementadas, Configuración de seguridad y QoS basada en directivas. En Configuración de Usuario se visualizan las siguientes opciones: La opción para generar scripts como en la sección de Configuración de equipos, pero esta solo infiere en la sesión de usuario (apertura y cierre de sesiones)
- Plantillas Administrativas: Este apartado tiene un gran uso y es una de las opciones más utilizadas ya que se permite los ajustes con relación a los ajustes del equipo, panel de control, inicio de sesión, apagado, etc.

Si bien, son muchas las opciones y variantes que, a tener en consideración, aquí se plantean algunas de las que se deberían tener en cuenta.
Además, hay que tener en cuenta los requisitos al seleccionar las opciones.

Hay algunas que dan solo la opción para Windows Server 2003, XP y Windows 2000 (Como es el caso de la opción “Evitar que las tareas se ejecuten o finalice” en Programador de tareas) Mientras que otras como en la solapa de Opciones de Inicio de sesión de Windows específica que es a partir de Windows Vista

En Configuración de Usuarios -> Plantillas Administrativas -> Sistema -> Ejecutar sólo aplicaciones especificadas de Windows -> Esta opción permite indicar qué programas no puede ejecutar el usuario. Se debe aclarar que solo impide que los usuarios ejecuten programas iniciados por un proceso del explorador de Windows.
Tampoco impide que ejecute el administrador de tareas, tampoco es un problema para el usuario que pueda acceder al símbolo del sistema (cmd.exe) ya que desde esta ventana pueden iniciar cualquier ejecutable.

En Configuración de Usuarios -> Plantillas Administrativas -> Sistema -> Impedir el acceso a herramientas de edición del Registro -> Si se encuentra habilitada y con la opción correspondiente, el usuario no podrá ingresar al registro de Windows (regedit.exe) al querer realizar esta opción, el sistema le devuelve un cartel informativo que esta acción fue bloqueada.

En Configuración de Usuarios -> Plantillas Administrativas -> Sistema -> Impedir el acceso al símbolo del sistema causa el efecto de que el usuario no puede acceder a la consola de comandos.

En la sección de Configuración de usuarios -> Plantillas Administrativas -> Sistemas -> Opciones de Ctrl - Alt - Sup -> aquí se puede denegar al usuario que pueda cambiar la contraseña, y que no aparezca la opción de Abrir Administrador de tareas.

En Configuración de usuarios -> Plantillas Administrativas -> Sistemas -> Administración de comunicaciones de internet -> Configuración de comunicaciones de internet hay varias opciones, pero la que más llama la atención, y si realmente no es requerida en la empresa, se puede desactivar las impresiones a través de HTTP (esto hace que, desde el determinado host, no pueda imprimir nada que esté en nuestra intranet o desde internet)

Configuración de usuarios -> Plantillas Administrativas -> Sistemas -> Acceso de almacenamiento extraíble aquí hay varias opciones que nos proporciona la liberad de denegar el acceso de lectura, de escritura o ambos en medios como DVD/CD, discos extraíbles, reproductores multimedia, teléfonos móviles y otros. - También se define en Configuración de Equipo -> Plantillas Administrativas -> Sistemas -> Acceso de almacenamiento extraíble (pero esas políticas aplican independientemente del usuario).
Esta política sólo impide que se acceda desde el explorador de Windows, pero no evita que se auto ejecute dicho dispositivo. Lo más sencillo es elegir la opción “Todas las clases de almacenamiento extraíble: denegara acceso a todo”. Y habilitarla.

En configuración de equipo -> Plantillas Administrativas -> Sistema -> Restaurar sistema se puede negar que el usuario lo utilice indebidamente. - Esto se chequeo en la versión Windows 7 y Windows 10 funciona sin problemas.

En Configuración del equipo -> Configuración de Windows -> Configuración de seguridad-> Directivas de cuenta -> Directivas de contraseñas aquí existen algunas opciones interesantes para tener en cuenta ya que nos presenta las opciones de Exigir un historial de contraseñas, esto nos permite determinar que cuando un usuario cambie su contraseña, no sea la misma. También se puede indicar los requisitos de complejidad de las contraseñas, su longitud mínima y los intervalos de vigencia de una contraseña (periodo mínimo y máximo)

En Configuración del equipo -> Configuración de Windows -> Configuración de seguridad-> Directivas de bloqueo de cuenta en esta sección se puede determinar la duración del bloqueo de cuenta (en minutos), cuanto tiempo debe pasar para desbloquearlo y luego definir la cantidad de veces que una persona puede equivocarse antes de bloquear la cuenta, con esta última se recomienda un número reducido de veces para evitar las técnicas de fuerza bruta.

En Configuración del equipo -> Configuración de Windows -> Configuración de seguridad -> Directivas locales -> Directiva de auditoría. Esta opción brinda la posibilidad de generar un registro de eventos con respecto al acceso de objetos, inicio de sesión y permisos que hacen los usuarios - Recomendado usarlo con Active Directory.

En Configuración del equipo -> Configuración de Windows -> Configuración de seguridad-> Directivas locales -> Opciones de seguridad hay varias opciones interesantes, como, por ejemplo, configurar los parámetros para que un usuario estándar ni siquiera pueda modificar el control de cuentas de usuario, cambiar el nombre de la cuenta de invitado y administrador, cambiar sus estados, etc.

Métodos de Autenticación de Usuarios

Hay que comprender los diferentes métodos que existen para la autenticación, esto podrá ser de ayuda para encontrar que existen más de una opción a la hora de definir cómo autenticar a un usuario.

Contraseñas:

Se trata de la técnica de autenticación más ampliamente extendida y con la que todos los usuarios están familiarizados. Aun así, se trata de la forma de autenticación más débil.

Certificados digitales:

Estos, constituyen una tecnología todavía no tan extendida como el método anterior. Contienen datos sobre la identidad de su titular, como su nombre, organización, país, dirección de correo electrónico, etc. Dado que para acceder a ellos es necesario el conocimiento de una clave secreta y/o el acceso a un dispositivo físico como una tarjeta inteligente, se asume que su poseedor es quien el certificado atestigua que es.

Identificación biométrica:

La identificación del usuario se produce en base a rasgos propios e irrepetibles de su persona, como sus huellas dactilares, su voz, la geometría de la palma de su mano o la configuración de su retina. Este método sí que identifica al usuario, ya que cuando estos dispositivos funcionan correctamente, sólo un individuo puede ser identificado con éxito, en virtud de una acertada elección de los parámetros fisiológicos a evaluar. En Windows 10 “Windows Hello” es quien proporciona este servicio.

Autenticación multifactor:

Los mejores métodos de control de acceso son aquellos que hacen uso de una combinación de los tres anteriormente mencionados, lo que se conoce como autenticación multifactor. Por el momento en lo que concierne a Sistema Operativo puntualmente en las plataformas Windows existe la opción de dar una contraseña, ingresar un pin o elegir una imagen como “Contraseña de imagen”. Generalmente se utiliza la contraseña convencional.

Detalles de las Contraseñas:

Como norma general, no se recomienda utilizar las sugerencias de contraseñas para cuando éstas se han olvidado, ya que serán visibles por todas las personas con acceso físico al equipo. En caso de usarse, se debe indicar una pista que solo aquella persona que tenga acceso a la contraseña pueda relacionar y recordar.
Algunos de los aspectos a tener en cuenta a la hora de elegir una contraseña son:

- Tener una complejidad de contraseñas: Es decir no puede ser una contraseña muy fácil de adivinar ya que ante un ataque de diccionario (*) o fuerza bruta (**) no durará mucho. Lo mejor es tener una longitud mínima de por ejemplo ocho caracteres, usando caracteres alfanuméricos y especiales (por ejemplo, el punto, guión, signo pesos, etc.).

Algunos consejos a seguir con respecto a ataques de diccionario serían por ejemplo son:

- Utilizar palabras en distintos idiomas en la misma contraseña MiPassword.
- Escribir las palabras con números o caracteres especiales intercalados M1C0ntr4señ4.
- Insertar dobles consonantes en algunas sílabas Conntrasseña.

En resumen, una buena contraseña siguiendo con estas directivas podría ser "-MyC0nTrr4s3ñ4."

(*) Ataque de diccionario: Método empleado para romper la seguridad de los sistemas basados en contraseñas (password) en la que el atacante intenta dar con la clave adecuada probando todas (o casi todas) las palabras posibles o recogidas en un diccionario idiomático. Generalmente se emplean programas especiales que se encargan de ello.
(**) Ataque de fuerza Bruta: Es la forma de recuperar una clave probando todas las combinaciones posibles hasta encontrar aquella que permite el acceso.

- Poseer un límite de intentos: Es decir, limitar los intentos de contraseñas que se pueden ingresar, así se puede evitar que el atacante comience un proceso indeterminado probando contraseñas hasta dar con la correcta. La idea es configurar un límite de cinco intentos, luego de ese número de intentos, la cuenta quedará bloqueada durante un tiempo determinado.
- Caducidad de Contraseña: Es recomendable cambiar las contraseñas con periodicidad, de no ser así, una contraseña indefinida en el tiempo tarde o temprano es descubierta.
- Historial de contraseñas: Es importante cambiar las contraseñas como se mencionó en el punto anterior, pero si se reutilizan las contraseñas no sirve de nada. Debe prohibirse la reutilización de contraseñas antiguas, ya sean iguales o parecidas.

Si bien, en muchos casos las PyMEs no tienen posibilidad de actualizar la versión del sistema operativo, sea por cuestiones de licencias, cuestiones de no poder tener los recursos mínimos o por otra circunstancia, nos encontramos que quizás poseen Windows XP y algunas con Windows 7.
Es de vital importancia tener conocimiento que al día de la fecha ambas versiones dejaron o dejarán de tener soporte de Microsoft, esto incluye parches de seguridad y otro tipo de actualizaciones.

Por lo tanto, es altamente recomendable que, en el menor tiempo posible, las terminales posean Windows 10 siempre y cuando los recursos lo permitan, en caso contrario, se deberán aplicar los parches de seguridad necesarios y configuraciones que así requieran para poder reducir el riego lo mejor posible.

Con respecto a los parches que publica Microsoft siempre es bueno estar actualizado, aunque con cierto cuidado, últimamente las actualizaciones, por alguna razón traen aparejados más problemas que soluciones, lo mejor es esperar un poco, un lapso de dos semanas desde el lanzamiento del parche, para verificar que sea estable y luego instalarlo.

Un gran problema que surge al utilizar el sistema operativo de Microsoft, en todas sus versiones, es que por lo general no se compran las licencias y para solucionar este problema, en muchos casos se habilita el sistema operativo a través de algún activador. Ejemplos de estos están “Microsoft ToolKit” y “KMSAuto”.

Esto representa un potencial riesgo para nuestra organización, hay varias razones, una de ellas es que, al ser una aplicación de terceros, no se sabe a ciencia cierta que se está ejecutando, además que se ha detectado que instalan servicios sin consentimiento explícito del usuario, los cuales transmiten información a terceros sin tener pleno conocimiento de ello.

Además, surge otro problema que es que, si se lee en alguna Página web, se indica desactivar el antivirus y otros productos como firewall y ejecutar como Administrador. Hay varios riesgos que se asumen al realizar estas acciones.

Si el archivo está infectado y desactivamos las defensas, estamos expuestos totalmente, si ejecutamos como administrador, le estamos dando privilegios como administrador y esto facilita muchos accesos que puede tener un software malintencionado.

Lo más recomendable es adquirir una licencia válida para no tener la necesidad de hacer uso de estos procesos dudosos.

Hay que tener en cuenta lo siguiente, no es que Microsoft sea inseguro como se piensa comúnmente. Hasta antes de Windows 2003, el enfoque de Microsoft “permitir todo aquello que no esté expresamente prohibido” En palabras más sencillas, es como dejar una casa con todas las puertas y ventanas abiertas y el administrador debe ir cerrando las puertas y ventanas que él considere inseguras, puede ocurrir que se olvide de cerrar alguna puerta o ventana generando así posibilidades para un intruso.

Servicios

Su descripción rápida sería que un servicio no es más que programa o aplicación en ejecución en segundo plano, algo con lo que a nivel de usuarios no se debe interactuar pero que es totalmente necesario para el funcionamiento del sistema, algo que está ahí trabajando pero que no percibimos.
A diferencia de los procesos, los servicios no se pueden cerrar o eliminar, lo único que se puede hacer es detenerlos o reiniciarlos, pero en ningún caso "matarlos".
Hay Servicios que no importa si el equipo es servidor o cliente, o ambos casos al mismo tiempo, Windows posee servicios activados desde su instalación inicial. Los mismos tienen cuatro estados: Automático, Automático (Inicio retrasado), Manual y Deshabilitado. Ver **Anexo "D"** con el título "Servicios"

- Automático: Al iniciar el sistema operativo estos servicios inician sin intervención del usuario
- Automático con Inicio retrasado: Significa que después de iniciar Windows y cargar todos los servicios necesarios y además cargar aquellos que tengan inicio automático, se cargarán estos servicios, por eso inicio retrasado.
- Manual: Esta opción, permite que, con intervención del usuario, se puedan iniciar servicios a voluntad en el instante que el usuario lo requiera.
- Deshabilitado: Si un servicio aparece en nuestra lista con esta opción, el servicio no se ejecutará y no se podrá iniciar posteriormente al inicio del sistema operativo, con o sin intervención del usuario.

Hay servicios que el puesto de trabajo no utilice, se pueden deshabilitar y esto brinda la protección que ese servicio no inicia para poder ser utilizado por un criminal y además mejoraría el rendimiento de la terminal.
Hay que entender que, si el puesto de trabajo no realiza alguna tarea específica, se podría deshabilitar el servicio, por ejemplo, el servicio de cola de impresión, si el usuario no imprime, éste podría deshabilitarse. A continuación, a modo de ejemplo se nombrarán algunos servicios que podrían ser deshabilitados sin afectar al funcionamiento del sistema operativo.

Administración de autenticación de Xbox Live:

Proporciona servicios de autenticación y autorización para interactuar con Xbox Live, este servicio viene configurado como manual, pero debido a que este servicio no tiene ninguna aplicación en nuestra PyME, debería quedar como deshabilitado

Administrador de conexiones automáticas de acceso remoto:

Crea una conexión a una red remota siempre que un programa hace referencia a un nombre o dirección DNS o NetBIOS remoto. Este servicio, puede que sea usado. Si bien viene configurado manual, debería estar deshabilitado aplicando la política de seguridad que los usuarios sin privilegios no puedan modificar.

Administrador de mapas descargados:

Servicio que se utiliza para el acceso de las aplicaciones a los mapas descargados.
Hay variedad de servicios que algunos están en forma "MANUAL" que podrían deshabilitarse. La lista es extensa, por lo cual solo se mostraron algunos ejemplos, esto requiere algo de tiempo y chequear cuales podrán deshabilitarse teniendo en cuenta que el servicio no tenga otras dependencias que produzcan un problema posterior.

Programas que utilizan los usuarios:

En la mayoría de circunstancias, en vez de cerrar la sesión resultará más sencillo utilizar la función Ejecutar como (Windows XP/Windows Server 2003
A partir de Windows 7 esto cambia y directamente abrirá todos los programas como usuario Administrador.
Si algunos programas los ejecuta siempre como otro usuario, es interesante saber que se puede ahorrar tiempo usando otra opción, se detalla en la sección de **Anexo "E"** con el título "Ejecución de programas como usuario Administrador/Otro Usuario"

Existen multitud de programas incorporados por defecto al sistema operativo, típicamente invocados por los ciber-delincuentesncuentes en sus ataques. Normalmente, estos programas no tienen porqué ser llamados por usuarios normales del equipo ni mucho menos por el usuario Sistema local (LocalSystem). Por tanto, una buena práctica consiste en eliminar todos los permisos de usuarios diferentes de aquellos administradores que de verdad los necesiten.
Evidentemente, en lugar de dar permiso individualmente a cada usuario, se debe crear un grupo especial para este fin y otorgar permiso de ejecución a los usuarios del grupo, mientras que se revoca para todos los demás usuarios, evitando así que se nos olvide o se nos pase por alto algún programa o privilegio.

Después de leer distintas fuentes de información, siendo estas consultas en internet mayormente, bibliografía (las cuales se adjuntan en la sección Bibliografía) y realizando algunas pruebas en un entorno virtualizado, teniendo en cuenta lo anteriormente mencionado y luego de analizar distintos programas que se listan a continuación, se llegó a la conclusión que un usuario podría ocasionar un grave daño a los equipos o incluso robar información crítica, es importante resaltar que si bien éstos brindan muchas facilidades, también son aprovechadas por los ciber-delincuentesncuentes para su provecho, o bien un usuario malintencionado o por desconocimiento. La siguiente lista pretende identificar aquellos ejecutables que deben prestarse atención.

cmd.exe ->

Ejecuta la consola de Comandos, la cual si se sabe utilizar apropiadamente puede ser una potente herramienta tanto para ayudarnos como para realizar alguna acción no favorable para los datos o el equipo. En las pruebas realizadas, se puede ver que mediante la consola es posible invocar cualquiera de los siguientes programas, y si son utilizados con malas intenciones, podría generar un problema de seguridad.

arp.exe ->

El programa recibe o envía datos en puertos abiertos a una LAN o Internet.

at.exe ->

Programa utilizado para que los comandos y programas se ejecuten en una computadora a una hora y fecha específicas (similar a cron). En Windows XP está habilitado, en Windows 10 se verifica que está deshabilitado.

finger.exe ->

Protocolo de red - Muestra información sobre un usuario o usuarios en una computadora remota especificada que ejecuta el servicio de finger. La computadora remota especifica el formato y la salida de la pantalla de información del usuario.

ftp.exe ->

Inicia y permite la conexión con FTP. Esto podría generar un “repositorio” el cual el atacante puede usar con varios fines.

ipconfig.exe ->

Permite mostrar información de IP, así como liberarla, renovarla y otras opciones.

netstat.exe ->

Muestra las estadísticas del protocolo y las conexiones actuales de TCP/IP usando NBT (NetBIOS sobre TCP/IP).

net.exe ->

Ofrece funciones adicionales a su red de área local vía la línea de comando del DOS. posee bastantes opciones, entre una de ellas es “Net User”

netstat.exe ->

Muestra estadísticas de protocolo y conexiones de red de TCP/IP actuales. Esto podría ser utilizado para rastrear e identificar otras terminales en la red.

nslookup.exe->

Utilizado para saber si el DNS está resolviendo correctamente los nombres y las IPs. Se utiliza con el comando nslookup, que funciona tanto en Windows como en UNIX para obtener la dirección IP conociendo el nombre, y viceversa.

ping.exe->

Comprueba el estado de la comunicación del anfitrión local con uno o varios equipos remotos de una red.

regedit.exe ->

Abre el registro de Windows, esto puede ocasionar innumerables trastornos.

route.exe->

Manipula tablas de enrutamiento de red.

rsh.exe->

Proceso de TCP/IP Remote Shell Command (actualmente no se encuentra al menos en Windows 10).

telnet.exe->

Permite que se conecte a otro equipo de forma remota (actualmente está deshabilitado, pero existe la posibilidad de habilitarlo).

tracert.exe ->

Se utiliza para trazar la ruta de los saltos que genera un paquete de datos a través de los routers.

xcopy.exe ->

Utilizado para copiar árboles de directorios y archivos.

taskmgr.exe->

Ese es el ejecutable del administrador de tareas que mediante él se puede obtener mucha información, desde que procesos están en ejecución, lista de usuarios, etc.

net start->

Muestra los servicios iniciados en Windows en el momento que se ejecuta este comando.

Para realizar algunas pruebas, se utilizó una herramienta para virtualizar tres computadoras, es decir, crear una versión virtual de distintas versiones de sistemas operativos, estas son Windows XP, Windows 7 y Windows 10 con el fin de verificar la ejecución de algunos de los programas anteriormente mencionados.

IPCONFIG.exe

Un atacante podría ver con el comando IP, sea que esté delante del equipo o que lo haga remotamente, puede ver los datos que se muestran a continuación, adicionalmente, puede ejecutar las opciones que tiene dicho comando, por ejemplo, ipconfig /release hace que blanquee estos datos.

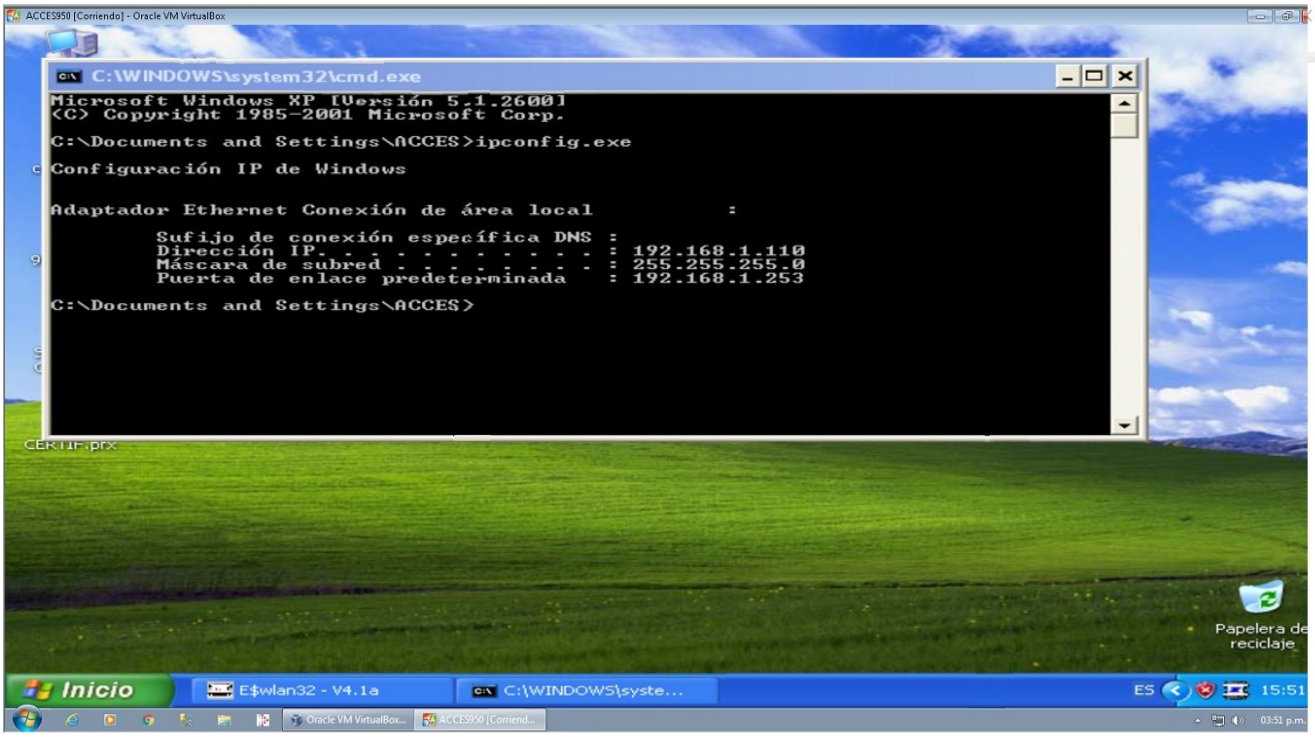

Fig. 2 – Imagen de Prueba usando comando IPCONFIG

ARP.exe

Como se observa en la imagen, se utilizó el ARP con la opción -a lo cual lista las entradas en la tabla ARP actuales, esto es un problema a nivel de seguridad, porque además de poder relevar cuales son las direcciones que la tabla ARP utiliza, también es posible por ejemplo con la opción correspondiente, agregar una entrada con la IP que se desee, facilitando así algún acceso no autorizado.

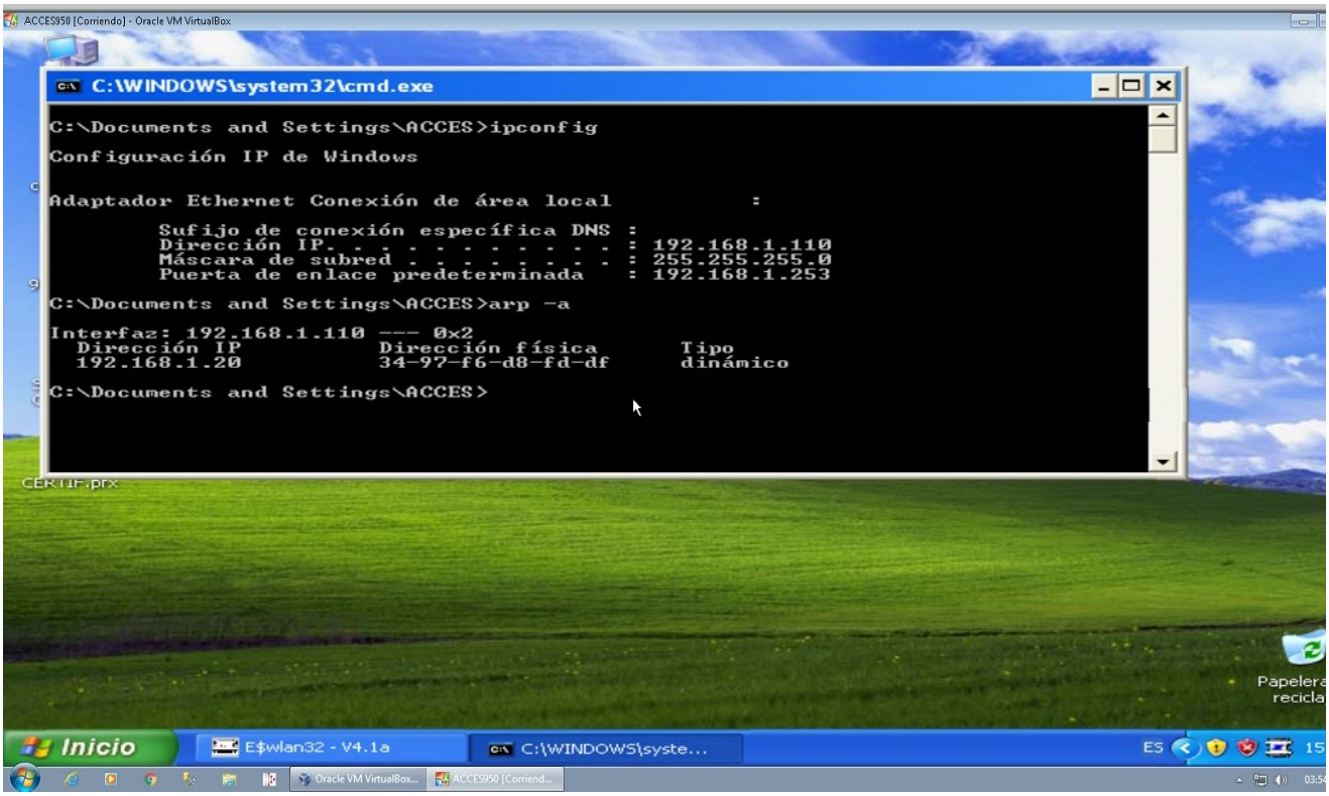

Fig. 3 – Imagen de Prueba usando el comando ARP

AT.exe

Si se ingresa solo el comando “AT” en la consola de comandos, se mostrarán las tareas programadas en forma de lista, de no haber ninguna tarea programada puede mostrarnos el siguiente mensaje: “No hay entradas en la lista.” En principio no parece generar ningún problema, de hecho podría hasta incluso facilitar la tarea si se sabe utilizar, pero si esto se combina, y por ejemplo, se crea un .bat con un código sencillo, que solo muestre un mensaje.

```
<Código>
@echo off
echo “hola, esto es una prueba”
pause
<fin de código>
```

Y si a su vez utilizamos el comando AT indicando por ejemplo que se inicie este código (anteriormente guardado como Prueba.bat en la raíz del disco C:\)
Cuando se cumpla la hora especificada en conjunto con el comando /interactive, ejecutará este .bat dando el resultado de una ventana de la consola de comando indicando el mensaje: “hola, esto es una prueba” como se muestra a continuación.

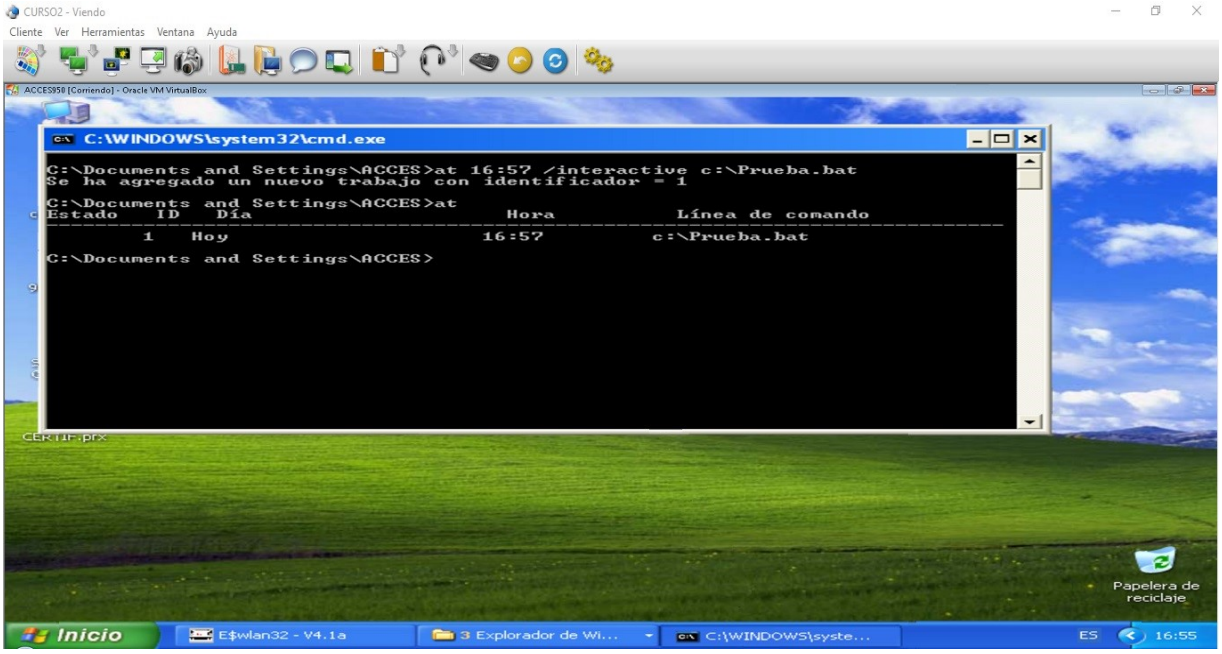

Fig. 4 – Imagen de Prueba usando el comando AT

Aquí se creó la tarea para que se ejecute 16:57 con /interactive y que ejecute el código en C:\Prueba.bat. Si listamos de nuevo la tarea con AT se puede ver el listado (observar que la hora del sistema indica 16:55).

A continuación cuando se cumple 16:57 ejecutará automáticamente el comando especificado, en este caso es Prueba.bat dando como resultado lo mostrado en la imagen.

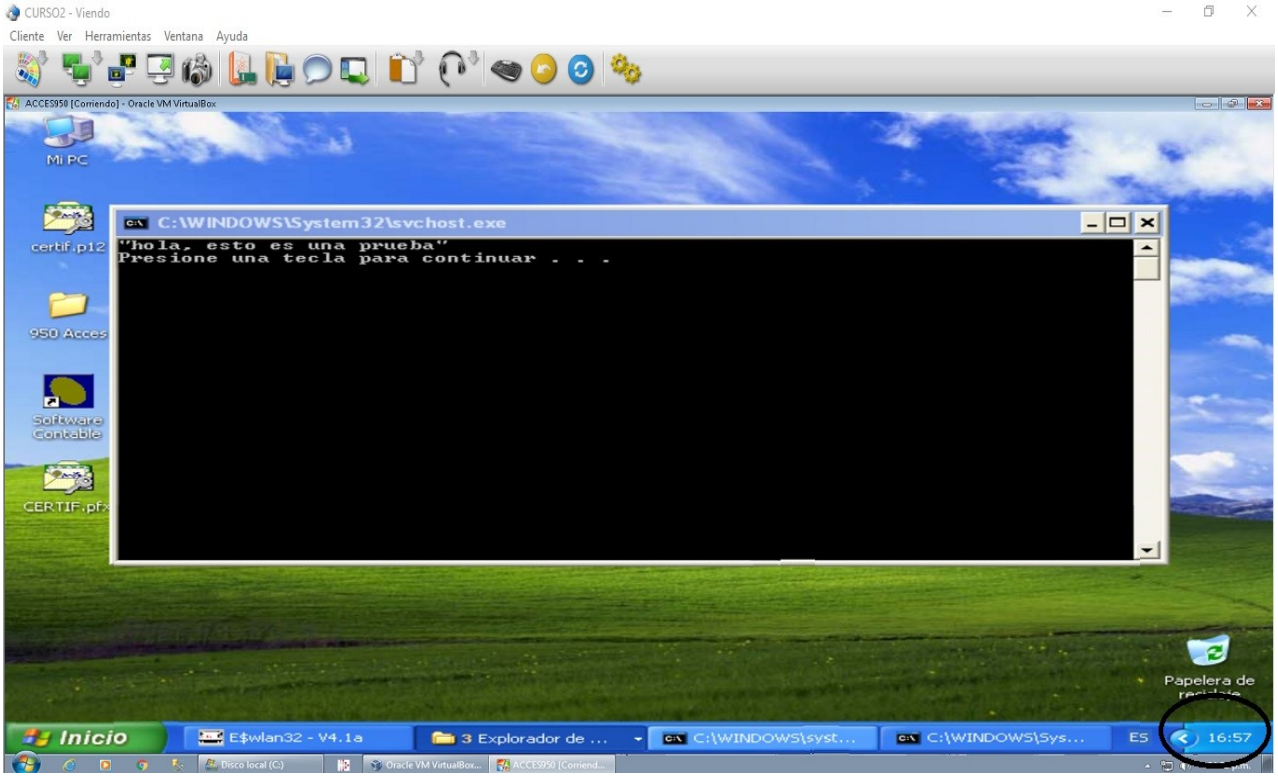

Fig. 4.1 – Imagen de Prueba usando el comando AT

Así pues, es evidente que si este .bat hubiera sido en su lugar un virus, estaríamos en problemas. En Windows 10 el comando AT se reemplaza por schtasks.exe

Netstat.exe

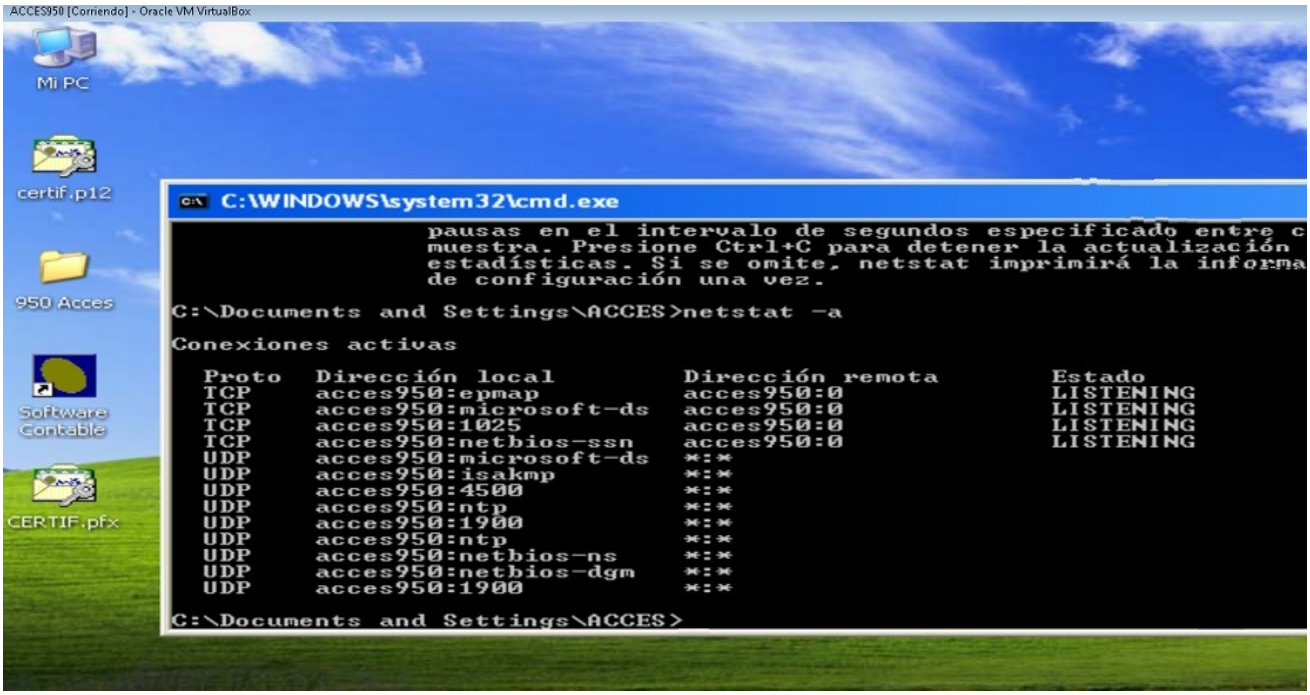

Fig. 5 – Imagen de Prueba usando el comando netstat

Con este comando y el parámetro -a por ejemplo se puede ver todas las direcciones locales, su estado y las conexiones TCP/IP actuales.

Net.exe

Si alguien logra poder ejecutar este programa, tiene la posibilidad de hacer varias cosas, entre ellas puede listar los usuarios, ideal para un atacante que busca información. Es posible también utilizar el comando Net User para modificar, dar de alta o modificar una cuenta y otras variantes.

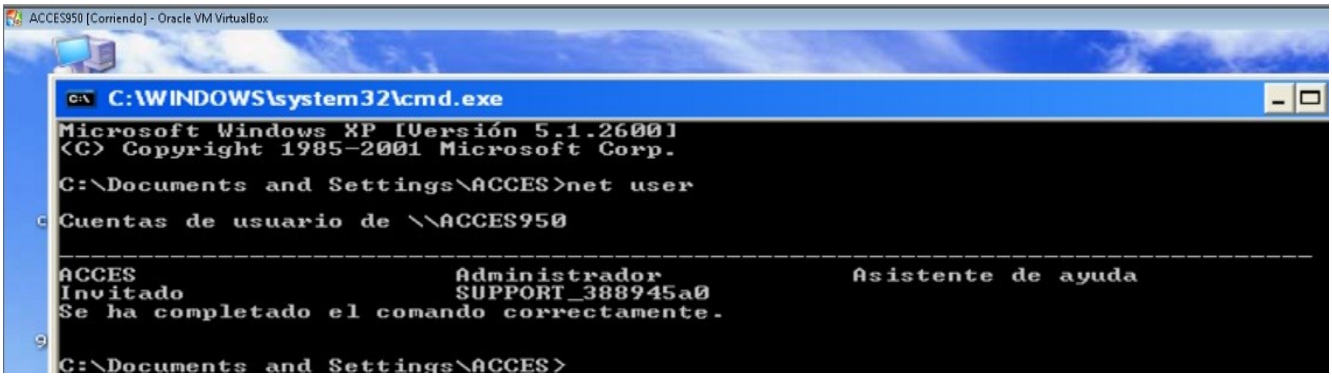

Fig. 6 – Imagen de Prueba usando el comando net User

En esta imagen se realizó un ejemplo para ver el listado de los usuarios en un pc virtual que trabaja por Grupo de trabajo.

```
Símbolo del sistema
Microsoft Windows [Versión 10.0.18362.418]
(c) 2019 Microsoft Corporation. Todos los derechos reservados.

C:\Users\[redacted]bajo7>net user /domain
Se procesará la solicitud en un controlador de dominio del dom

Cuentas de usuario de \\SERVER2008.Domain.[redacted].com.ar

-------------------------------------------------------------
Admi[redacted]          al[redacted]                ASPNET
car[redacted]           Invitado                    krbtgt
mas[redacted]           Notebook                    [redacted]gio
[redacted]bajo0         [redacted]bajo1             [redacted]bajo2
[redacted]bajo3         [redacted]jo4               [redacted]bajo5
[redacted]bajo6         [redacted]bajo7
Se ha completado el comando correctamente.
```

Fig. 6.1 – Imagen de Prueba usando el comando net User /domain

En esta imagen se puede ver que se usa el comando net User /domain para listar los usuarios en un dominio, esto en un usuario con pocos privilegios no debería permitirse.

PING.exe

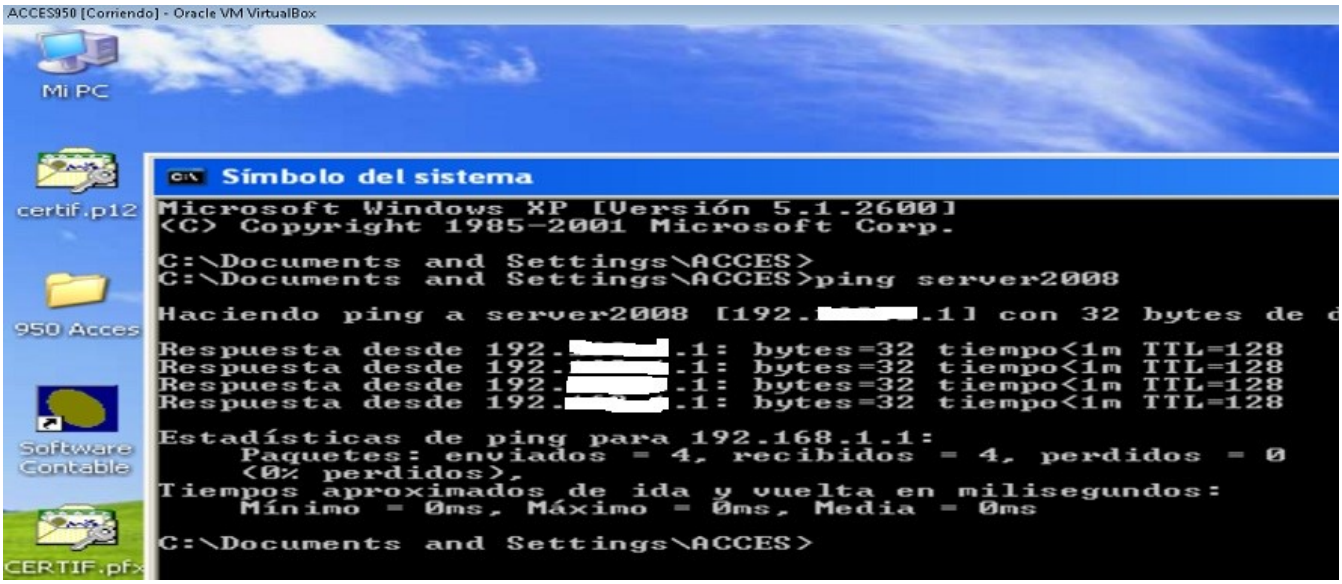

Fig. 7 – Imagen de Prueba usando el comando ping

Route.exe

Usando el comando Route - otra opción como por ejemplo ROUTE PRINT, indica cómo se visualiza en la imagen la tabla mostrando varios datos. Además, hay otras opciones como por ejemplo agregar una ruta

Fig. 8 – Imagen de Prueba usando el comando Route print

Tracert.exe

Si se ejecuta desde la consola tracert y por ejemplo se le indica una dirección de IP en el caso de la imagen es al DNS de google 8.8.8.8 entonces, muestra cuantos saltos de router tiene y la métrica.

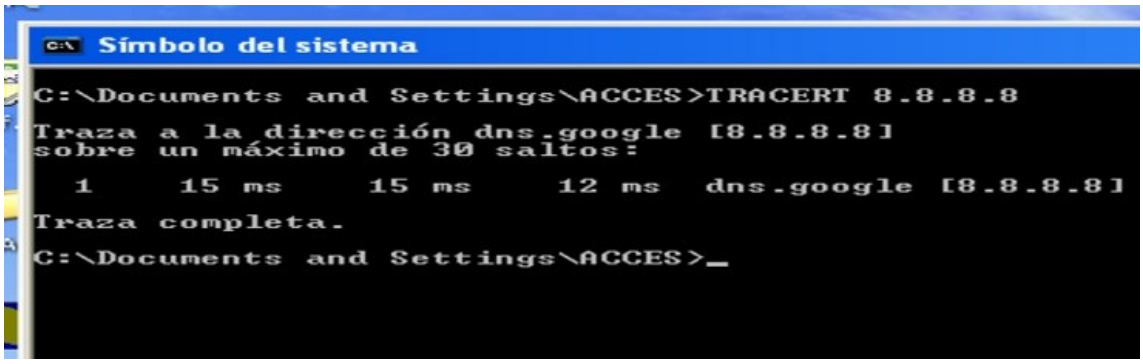

Fig. 9 – Imagen de Prueba usando el comando tracert

Algo fundamental es consultar las políticas de privacidad de ese antivirus. Usualmente el software que se instala, no se desea utilice los datos propios para fines publicitarios, por ejemplo. A veces se pueden encontrar por ejemplo con antivirus gratuitos que lo que buscan es sacar beneficio a través de los datos propios. Leer cuidadosamente la política de privacidad del software es una buena idea para evitar problemas en el futuro.

En muchos antivirus también se encuentra la opción de Baúl el cual almacena archivos potencialmente peligrosos para los sistemas utilizado, si no se desea publicar dichos archivos a la firma de antivirus por citar un ejemplo, se recomienda vaciar el baúl, ya que es desperdiciar espacio en los equipos (Si bien hoy día el espacio es abundante, lo mejor se trate de mantener lo más limpio posible).

La verdad que hay mucha variedad, hoy día son muchas alternativas que hay en el mercado, esto incluyendo freeware (software gratis) software (software con periodo de prueba, normalmente 30 días) y por último software pagos. La intención de este trabajo no es inclinarse por una marca en específica sino, mencionar que conceptos son importantes a tener en cuenta

Se determinó que hay factores importantes a tener en cuenta a la hora de elegir alguna solución antivirus para nuestra organización y los módulos o prestaciones mínimas que deberían tener en cuenta son las siguientes:

- <u>Recursos utilizados:</u>
  Es decir, cuántos recursos destinados para esta solución y que consecuencias trae aparejadas en el uso normal de otros softwares o la PC en general. Lo que ocurrió es que una de las firmas antes mencionadas, al ejecutar el proceso de análisis de búsqueda de amenazas consumía demasiados recursos y principalmente en el uso de memoria RAM.

- Base de datos de firmas:
  Esto refiere a si dicha base que además es actualizada periódicamente, una base de datos de firmas es básicamente una base de datos la cual contiene la secuencia continua de bytes comunes en cierta muestra de malware. El antivirus compara su base de datos con un archivo sospechoso y si esa secuencia de bytes coincide puede afirmar que el archivo sospechoso está infectado.

- Velocidad de escaneo:
  Es decir, la proporción de tiempo que se tarda en realizar un escaneo al dispositivo.

- Módulos del software:
  Esto refiere a si tiene otros módulos más como podrían ser Firewall, protección anti - Phishing, etc.

- Sistema de Heurística utilizado:
  Se refieren a las técnicas que emplean para reconocer códigos maliciosos que no se encuentren en su base de datos (ya sea porque son nuevos, o por no ser muy divulgados)

Consideraciones sobre antivirus: Además de las diversas recomendaciones que se pueden encontrar en cualquier fuente de información, se realizó una pequeña prueba donde se virtualizó un pc con distintos sistemas operativos y se le instalaron más de un antivirus. El resultado fue poco alentador, parecería que mientras más de estas soluciones de software estén instaladas, más protegidos estamos, esto es un error, ya que lamentablemente, en la prueba realizada, la pc comenzó a presentar algunas fallas como problemas de rendimiento, detección como amenaza a otro antivirus, el mal funcionamiento de varios módulos y con el adicional que si un antivirus encuentra y elimina un malware, o lo lleva al baúl de virus (también conocido como cuarentena) los otros antivirus comienzan a notificar que se elimina una amenaza y se torna bastante molesto. Por estas razones, es conveniente solo tener una solución antivirus instalada en cada host o servidor.

Firewalls

Se pueden definir generalmente como un dispositivo conformado por uno o varios equipos que permiten, limitan, cifran y descifran los paquetes que transitan entre dos redes (generalmente la red de la empresa e internet) de acuerdo a un criterio previamente establecido. Su implementación puede ser mediante Hardware o Software o usar la variante de un híbrido (Hardware y Software)

Algunas de las funciones que debería tener cualquier firewall:

General:

- Crea un perímetro de seguridad y defensa de la organización.
- Posibilidad de implementar seguridad entre las distintas áreas de la organización.
- Debe ser rápido (Concierne tanto al hardware y al software utilizados) y transparente al usuario ya que todo el tráfico de la organización pasaría por este punto, si su arquitectura no puede soportarlo, el firewall generará un cuello de botella haciendo saturar la red interna.
- VPN: Los firewalls también pueden actuar como servidores de redes privadas virtuales. En síntesis, es un túnel o canal seguro a través de Internet u otras redes públicas. El contenido de la conexión a través de Internet se cifra, de manera que sus datos quedan inaccesibles para el público, pero no para la red privada a la que se conecta. Las VPN se suelen utilizar para conectar dos redes locales a través de una red insegura como Internet. Gracias a la VPN, el ordenador remoto se conecta a la otra LAN como si estuviera directamente conecta a ella en local.
- Auditoría y registro de uso: El firewall constituye un buen lugar donde recopilar información sobre el uso de la red. En su calidad de punto único de acceso, puede registrar toda la actividad entre la red exterior y la interior. Con todos estos datos, el administrador puede posteriormente estudiar estadísticamente el tipo de tráfico, las horas de mayor carga de trabajo, el ancho de banda consumido y, por supuesto, todos los intentos de intrusión o las pistas dejadas por un atacante.

Hay que tener en cuenta que es habitual encontrar muchos productos que ofrecen múltiples funciones, pero en un entorno como una PyME lo ideal sería encontrar alguna opción que incluya: Análisis de tráfico malicioso, módulo de IDS/IPS, módulo para implementar reglas con alertas (es el módulo más común), módulo de Anti-DDOS y otras prestaciones como podrían ser VPN, proxy, etc.

Lo importante aquí es determinar qué implementar un firewall de manera incorrecta, puede provocar fallos en la actividad de lo que es la empresa u otros tipos de problemas.

Servicio en Capa 3 (Modelo OSI - Capa de Red):

- Limitar o bloquear el acceso servicios desde y hacia internet
- Impedir el acceso a determinados usuarios a servicios o servidores
- Monitorear las comunicaciones entre redes

Servicio en Capa 7 (Modelo OSI - Capa de Aplicación):

- Protección contra virus
- Protección contra vulnerabilidades conocidas

<u>Limitaciones de los firewalls a tener en cuenta:</u>

1. Un firewall no puede protegerse contra ataques que se efectúen fuera de su punto de operación.
2. Un firewall no puede protegerse contra ataques de ingeniería social.
3. Un firewall no puede proteger la red de los ataques dentro del ámbito de la red local.
4. Un firewall no puede proteger de los fallos de seguridad o de los servicios de los cuales se permita el tráfico.
5. Un firewall no puede proteger el envío de datos hacia fuera de la organización.
6. La instalación de un firewall carece de sentido si no va de la mano de una política de seguridad real.

Estos elementos, a diferencia del firewall, por ejemplo, nos protegen internamente también, generalmente se encargan de recopilar y analizar información de una red o un dispositivo para tratar de identificar posibles violaciones de seguridad, tanto internas, es decir desde dentro de la organización, como externas, ejemplo: Internet

Es quizás, un gasto bastante importante para un PyME, pero si está la posibilidad de implementar un IDS o un IPS, sería lo ideal ya que cubre ciertos escenarios que el Firewall por sí solo no podría hacer.

Las funciones de un IDS:

- Análisis de los usuarios y actividades del sistema.
- Análisis de las configuraciones del sistema y de sus vulnerabilidades.
- Evaluación de un sistema e integridad sus archivos.
- Capacidad de reconocer patrones típicos de los ataques.
- Análisis de los patrones de actividad anormales.

La diferencia fundamental entre un IDS y un IPS es que el IDS (Sistema de detección de intrusos) solo puede detectar anomalías pero no puede realizar ninguna acción, solo emite alertas, en cambio el IPS (Sistema de prevención de intrusos) posee la alternativa de realizar una acción proactiva, es decir, por ejemplo en una PyME se decide instalar un IPS, si él mismo detecta algún patrón o anomalía en algún equipo, éste procede a realizar la acción la cual fue configurada previamente, sin intervención de una persona.

En cambio, el IDS sólo detectará la anomalía y la informará.

Dispositivos de conexión de Redes

Con los avances tecnológicos, se han desarrollado dispositivos de mejor calidad o incluso, mejorando las prestaciones que brindan algunos dispositivos y se han ido reemplazando, aun así, hay organizaciones que por distintos motivos siguen manteniendo dichos equipos en funcionamiento.

Hubs:
Son dispositivos utilizados para generar redes de bajo coste.

Características:

Envía el mensaje a todos los dispositivos conectados, aunque éstos no le hayan solicitado ningún mensaje. Solo poseen un solo dominio de colisión.

Problema más común:

Posibilidad de sniffing de tráfico.

Posible solución:

Para prevenir atentados contra la confidencialidad, se deberá Cifrar el tráfico “sensible” de la red o cambiar de dispositivo, a un Switch

Switch:

Dispositivos que, con el tiempo, se redujo su coste y es el reemplazo de los Hubs.

Características:

Segmentación de redes (Interconecta dos o más redes) y su dominio de colisiones es igual al número de bocas conectadas que el dispositivo tenga. En un lenguaje un poco más sencillo de entender: Los Switches hacen que el tráfico sea solo remitido por las conexiones de los integrantes en la comunicación, en primera instancia impide la escucha de terceros (clara diferencia con el Hub).

Problema más común:

ARP Spoofing: Hay dos grandes grupos u enfoques de ataques que pueden darse:

- Engañando a las máquinas: Esto supone por ejemplo que el Intruso X le indica a la máquina A que la IP de la máquina B está asociada a la MAC de X mientras que al equipo B le dice que la IP de A está asociada a la MAC de X. Así el intruso X logra visualizar el tráfico entre A y B.
- Engañando al Switch: Este enfoque es similar al anterior

Un intruso astuto podría anunciarse con la MAC de un determinado equipo y el Switch actualizará su tabla ARP asociando dicha dirección a la nueva interfaz. Por ello conviene activar las opciones de prevención de falsificación de direcciones para evitar ser atacado con dicha técnica.

Otra forma de ataque consiste en inundar con direcciones MAC distintas unas determinadas interfaces de un Switch esperando que se sobrecargue y debido a ello, comience a funcionar en modo Hub. Este ataque puede funcionar en algunos dispositivos de bajo coste, si bien en los equipos profesionales no es un ataque válido.

MITM: Es otro de los problemas que presentan los Switches. MITM (Man in the Middle u “Hombre en el medio”) lo cual re direcciona las conexiones que pasan por un punto intermedio donde puede verse la información claramente.

Posible solución:

Control de dirección MAC sea por interfaz o consola. Creación de VLANS lo cual previene posibilidades de ataques MAC Spoofing

Router:

Este dispositivo interconecta redes distintas.

Característica:

Encamina paquetes de datos e interconecta redes diferentes, los Switches y los Hubs no poseen dicha característica, sólo conectan dispositivos dentro de una misma red.

Problema más común:

Inyección de rutas, e decir engañar al router con rutas que no corresponden a una ruta confiable.

Posible solución:

Algunas buenas prácticas nos permiten fortalecer estos dispositivos y evitar problemas:

- Configurar rutas estáticas para evitar la inyección de rutas ajenas y poco confiables.
- Aprender rutas dinámicamente sólo de orígenes confiables y, direcciones IP
- Filtrar tráfico por dirección IP y puerto no deseado.
- Evitar el tráfico ICMP desde el exterior contra los sistemas internos.

Adicionalmente, como en todos los niveles donde se requieren credenciales para acceder a la administración de un dispositivo o software, seguir las condiciones generales: Una contraseña robusta, inhabilitar usuarios por defecto y obviamente cambiar la contraseña que viene por defecto.

Capítulo – IV SEGURIDAD FÍSICA

Concepto General de Seguridad Física:

Si bien este documento pretende fortalecer a las PyMEs que utilicen cualquier versión de Windows para poder desarrollar su trabajo, también es conveniente poseer cierto conocimiento básico sobre este punto que muchas veces es olvidado. La Seguridad Física consiste en realizar procedimientos que puedan resguardar de alguna manera nuestros sistemas de amenazas físicas. Hay algunos lineamientos mínimos que se deben tener en cuenta, ya que algunas veces, los incidentes ocurren por descuido.

Amenazas naturales:

Existen una variedad de amenazas que no se pueden controlar, estas se manifiestan a través de la naturaleza, pudiendo ser huracanes, tormentas, inundaciones, incendios, terremotos, etc. Algunas de estas amenazas son variables ya que depende donde se encuentre situada la empresa, si se encuentra en Buenos Aires, Capital, es poco probable que la zona sufra de terremotos. Lo mejor es estar preparado para estos problemas, esto se refiere a que, si las instalaciones de la PyME están en un área por ejemplo de fácil inundación, aquellos equipos que posean datos sensibles deben estar a salvo. Ejemplo: Suponiendo que una empresa tenga una sala de servidores, no debería estar bajo ningún punto de vista en el subsuelo, ya que al inundarse el agua baja a los pisos inferiores haciendo así que se inunde el área y perdamos todo sin posibilidad de recuperarlo, o en su defecto, sería muy costosa su recuperación.

El problema de los incendios puede catalogarse de varias maneras, esto es así porque un incendio podría iniciarse como un acto de vandalismo, lo que hace que la naturaleza de esta amenaza sea el factor humano.

Un incendio también puede tener su origen sobre una mala conexión de suministro eléctrico, en algunas ocasiones las personas, para abaratar costos y ser más prácticas conectan varios dispositivos a una zapatilla eléctrica, esto puede iniciar un incendio.

Para evitar estos problemas podríamos, por ejemplo, utilizar detectores de humo en los lugares físicos donde se encuentren los equipos.

Es importante saber que los extintores son una buena medida para combatir los incendios, pero hay que tener en cuenta que los elementos químicos utilizados, podrían dañar significativamente nuestros equipos, además que para utilizar los extintores es recomendable que esas personas estén correctamente capacitadas.
El problema de las inundaciones también puede ser originado por un acto de vandalismo, o bien puede ser una ruptura de un caño, como medida se puede realizar una implementación del sistema de detección de líquido, estos usualmente poseen sensores que, si son correctamente colocados, es decir, por debajo del nivel de los equipos, cuando detecten líquido, apagarían los equipos automáticamente y cortarían el suministro de energía.
Quizás este tipo de sistemas para equipos de escritorio no sea justificable el gasto. Otra medida menos costosa sería colocar los equipos a nivel del escritorio.

Amenazas del Entorno:

En lo ideal, se recomienda vigilancia en los accesos del edificio, con identificador de tarjetas de identificación para los empleados y para aquellas áreas donde la seguridad deba ser mayor y tener a disposición personal de seguridad que controlen a las personas que entren y salgan del edificio. Además, cámaras de vigilancia, sean estas circuito cerrado o cámaras IP, en los accesos más críticos como podría ser la sala de servidores y otras tantas barreras físicas que quizás una empresa no puede acceder a dichas prestaciones.

● Suministro eléctrico:

En este punto, es importante remarcar que el área de sistemas no es quién será el encargado de llevar la implementación de la infraestructura eléctrica, pero es importante tener en cuenta que pueden surgir algunos conflictos que perjudican a nuestros equipos, siendo estos por ejemplo una mala conexión eléctrica podría generar un incendio en nuestras oficinas, poniendo en peligro la vida del personal y adicionalmente de la información que tienen los equipos.
Otro ejemplo no tan drástico es que se tiene la costumbre de una vez finalizada la jornada de trabajo en algunos casos no se apagan los equipos, en una tormenta eléctrica, podría dañar con una descarga eléctrica dejando los equipos inutilizados.
También, es probable ser víctimas de apagones en plena jornada laboral causando un efecto igual o similar al anterior descripto.

Para poder dar una solución alternativa a este tipo de problemas con respecto a la electricidad, se recomienda adquirir equipos denominados UPS (Sistema de Suministros Ininterrumpidos de Energía) dichos equipos cuentan con la capacidad de regular la tensión evitando los picos de voltaje que pueda traer la red y proporcionan un tiempo de autonomía por medio de baterías en caso de cortes del suministro eléctrico. Estas medidas pueden incluir también otro tipo de hardware como impresoras láser, fotocopiadoras, conectores de red, etc.

Una alternativa menos costosa, pero a su vez que no tenga las mismas prestaciones, es la implementación de estabilizadores de corriente eléctrica, esto permite en cierto modo, proteger nuestros equipos, ya que la entrada de tensión eléctrica pudiera ser más alta o más baja, el estabilizador, en un concepto general, trata de estabilizar las cargas crucitas y la tensión de la red para que los equipos no sufran estas anomalías. El problema es que no posee una autonomía propia, por lo cual, quizás salve al equipo de una tensión crítica, pero no evitará que se apague.

● Cableado de redes de datos:

Hace ya unos años que se han implementado las redes Wifi o redes inalámbricas, esto ha liberado a algunas empresas de la necesidad de implementar el cableado de redes por toda la empresa, pero aún hoy existen algunas empresas que siguen manteniendo este cableado sea por el motivo de comodidad, o porque la infraestructura no permite una buena conexión de tipo inalámbrica u otros motivos.

En algunos casos, el pasado del cableado se encuentra mal colocado, ya sea colocado en el piso con la posibilidad de que otra persona se tropiece, con la posibilidad de que con el paso del tiempo se deteriore o se rompa el cable, presentando la posibilidad de bajo rendimiento de la red o bien con la posibilidad de dejar sin servicio de red a la empresa.

En consecuencia, se recomienda que los cables no estén a la altura que puedan ocasionar estos problemas, de no ser posible esta medida, al menos tener el cuidado de entubarlos y que no se encuentren a la vista. Un detalle a modo de comentario es que no debe juntarse el cableado de redes de datos con el cableado de suministro eléctrico, esto ocasiona graves fallas en la red en cuanto a rendimiento.

Amenazas Humanas

● Acceso a los equipos:

Uno de los mayores descuidos que se han visto es que se dejan las oficinas abiertas donde están los equipos con información importante, o lo que es peor, un centro de cómputos con la puerta entreabierta y la llave colocada en el cerrojo. Este tipo de descuidos podrían generar varios trastornos a una PyME. Desde el robo de información, daño o robo de equipos hasta infección con algún malware y las variables son infinitos.

La mejor recomendación al menos que se puede brindar en este documento y que no genere mayores gastos a la empresa, es que, si se abandona la oficina de trabajo, al menos se debería tomar el recaudo de cerrar correctamente las puertas y ventanas con cerrojo, adicionalmente se aconseja que cualquier persona ajena a la empresa, bajo ninguna circunstancia debe tener acceso a los equipos, a menos que sean autorizados por quien corresponda.

Por otro lado, los equipos de red, es decir los routers, switches y patcheras, también conocidos como paneles de conexión, deben estar con acceso restringido. El robo o rotura de estos equipos que, gracias a ellos permite compartir información en toda la empresa y tener acceso a internet, podría significar pérdida de tiempo de trabajo. Tanto los Switch y los routers deberían de estar en la sala donde se encuentra el personal de sistemas, o bien en una sala aislada con acceso restringido.

Estos dos dispositivos tienen sus propios mecanismos de seguridad, pero en muchos modelos y marcas diferentes tienen la posibilidad de ser reiniciados y con ello sería borrada toda la configuración de seguridad.

Con respecto a las patcheras, que son un panel de conexiones de red, con forma muy parecida a las fichas de teléfono, si están distribuidas por la empresa sin ningún tipo de control, podrían ser usadas con la intención de infiltrarse a la red, solo bastaría conectar un equipo a la patchera para que éste comience a operar con su placa de red y mínimamente tendría acceso a los recursos compartidos de la empresa. Si nuestro entorno cuenta con patcheras distribuidas por toda a empresa, es altamente recomendable la inmediata des-habilitación de aquellas bocas que no cuenten con la vigilancia apropiada.

● Robo de equipos/sabotajes:

Como se menciona en el punto anterior, nuestra infraestructura está expuesta a este tipo de amenazas. Aunque muchas veces se espera que las amenazas tengan su origen del exterior de la empresa, es una realidad que la mayoría de estos problemas vienen realmente del interior, sea porque los empleados están insatisfechos, porque están siendo extorsionados de alguna forma u otros motivos.

Para hacer frente a estos problemas es necesario contar en lo posible con vigilancia de circuito cerrado, políticas claras de seguridad e informarse y generar documentos legales de la organización como podría ser un contrato de confidencialidad. Otra solución simple sería sellar el gabinete de los equipos e instruir al personal de mantenimiento para que ponga y quite los sellos cuando se realiza alguna manipulación dentro del gabinete. Otra opción bastante radical sería soldar el armazón, pero se haría imposible realizar un mantenimiento al mismo.

● Área de trabajo:

Poco se menciona de esta área. Lo que respecta a un día de jornada laboral, una persona si bien debe apoyarse hoy día en las facilidades que le brinda un sistema informático, es una realidad que se sigue utilizando el papel. El problema es que cualquier persona, aunque obre de buena fe, es muy común encontrar que dejan documentación con información sensible al alcance de cualquiera. Usualmente se cuenta con alguna documentación que una vez cargada en un medio informático, éste es descartado.

Aun así, hay algunas precauciones que deberían tomarse. Por ejemplo el simple acto de poseer papeles que sean los ingresos de nuestra empresa en la mesa, brinda mucha información para cualquier persona con malas intenciones, en estos documentos es común encontrar lógicamente el importe monetario que tiene la empresa, usualmente poseen fechas de entrega de depósito de dinero, datos personales de quien va a retirar el pago si es el caso de cheques (generalmente es el gerente/dueño de la empresa) y otros datos que podrían servir para utilizar ingeniería social.

Un ejemplo de un escenario que podría ocurrir sería que entra una persona desconocida a la empresa, se dirige al sector de trabajo de uno de los empleados, sea porque lo conoce o porque busca información de esa empresa en particular y en el escritorio de nuestro personal se encuentra la documentación que informa sobre quién es el gerente o el jefe a cargo del sector con nombre y apellido y su email, una vez se retira del establecimiento, este desconocido podría hacer contacto vía telefónica usando esos nombres que recuerda de aquel documento o bien puede utilizar el email que también observó anteriormente para realizar un ataque de Phishing.

Se debe definir y capacitar a los empleados para que no dejen ese tipo de documentación a tan fácil acceso. Si es documentación que no puede ser destruida debido a su naturaleza, al abandonar su puesto debería dejarse como mínimo en un cajón cerrado con llave, y la misma debe ser retirada.

Si es documentación la cual ya no es necesaria tenerla en papel y se puede destruir, utilizar alguna trituradora de papel, este dispositivo nos garantiza que esta documentación sea destruida y no pueda reconstruirse.

No se debe tirar la documentación a la basura, ya que existe la posibilidad de que ésta se recupere conservando su legibilidad. Es usual utilizar la técnica de Trashing o Dumpster Diving. Consiste en revisar la basura de la persona u organización a investigar obteniendo información que puede variar desde nombres de usuario y claves, información personal y otras formas de información sensible.

Otro elemento que se debe prestar atención además de los puestos de trabajo, son los dispositivos como discos extraíbles o pendrive siendo estos una herramienta muy versátil ya que permiten el traslado de información de un equipo a otro. Sin embargo, si son descuidados, alguien podría robar estos dispositivos con la información que tengan dentro. Otro problema es la curiosidad del ser humano, supongamos que somos un empleado en una PyME y antes de ingresar nuestra jornada laboral nos encontramos un pendrive tirado en la calle. La acción de colocar aquel pendrive "olvidado" en un equipo de nuestra PyME, podría llegar a ocasionar un gran problema de seguridad ya que al no saber cuál es su origen, no se puede garantizar que el dispositivo no esté infectado por una amenaza, siendo este virus, spyware u otros.

Existe otra posibilidad, esta vez "el actor" que interviene en este escenario son los usuarios, el simple hecho de olvidarse un pendrive en un equipo da la posibilidad de que el mismo sea robado, el delincuente puede correr con algo de suerte y dentro del dispositivo podría encontrar información valiosa o crítica de nuestra organización. Por otra parte, como ya se ha mencionado, no falta aquel usuario con malas intenciones el cual puede realizar cualquiera de las actividades antes mencionadas, robar información, propagar algún malware, etc.

A fin de combatir estos problemas es posible tomar algunas acciones, pero todas deben ser acordadas previamente por los involucrados (es decir con la gerencia de la organización, el sector que se ve afectado y el departamento de sistemas).

Se podría acordar que, dentro de la organización, no se usen pendrives, si bien esta medida es tajante y restringe a los usuarios de utilizar este tipo de dispositivos, se podrían ahorrar algunos problemas, en el caso de que esta medida fuera aceptada y aun así los usuarios sigan utilizando los puertos USB, se podrían deshabilitar desde el BIOS o también existe la posibilidad desde el Administrador de dispositivos deshabilitar los drivers (controladores) para evitar así que sean reconocidos.

Aun así, lo mejor es no restringir aquello que nos causa un problema, sino resolver el problema por otros medios. Lo mejor es que en conjunto se brinden las capacitaciones acordes a cada caso, es decir, la capacitación a los usuarios de las medidas mínimas que ellos pueden realizar sin conocimientos previos, las medidas que debería tomar aquel o aquellos encargados del departamento de sistemas y en conjunción con la gerencia redactar y cumplir con políticas de seguridad claras y que sean adaptables al negocio.

Planes de contingencia

Se define como “Contingencia” a la posibilidad de que algo suceda o no suceda. En el ámbito de Informática se refiere a la posibilidad de que se genere un evento no deseado, o bien que exista un potencial riesgo que genera una interrupción o mal funcionamiento de los sistemas informáticos dentro de la empresa.

Para hacer frente a este tipo de situaciones, se confecciona un Plan de Contingencia.

El mismo se define como un conjunto de medidas o actividades que permiten minimizar los riesgos en caso de algún incidente, sea de origen humano o natural, manteniendo así la operatividad de la empresa a un nivel mínimo hasta que pueda recuperar la totalidad de los sistemas o recursos afectados. Un plan de contingencia, como factores fundamentales tiene la prevención, detección y recuperación.

Con prevención se refiere a que se desarrolle algún mecanismo para ayudar a prevenir la mayor cantidad de eventos no deseados con el fin de reducir las consecuencias que pueden traer estos eventos.

Con detección se refiere a que se deben tomar las medidas necesarias para disminuir los eventos no deseados, durante o inmediatamente después de generarse un incidente que perjudique a la empresa.

Con recuperación se refiere a indicar algún procedimiento, el cual después de haber controlado el problema, se debe proceder a recuperar los equipos y las actividades a su estado anterior al incidente.

En primer lugar, se debe realizar un plan de acuerdo al entorno, parece obvio, pero a veces se diseñan planes que no tienen una aplicación práctica en el mundo real. Se debe realizar un diagnóstico actual y de forma total de la empresa, luego exponer los posibles problemas y encontrar más de una alternativa para resolver cada problema. Esto incluye también el inventario de los recursos informáticos y a su vez delimitando correctamente el alcance del plan de contingencia.

Es oportuno realizar un esquema de aquellas potenciales contingencias que pueda sufrir nuestra empresa, a modo de ejemplo se facilita un ejemplo general de cómo podría diagramarse este tipo de esquemas.

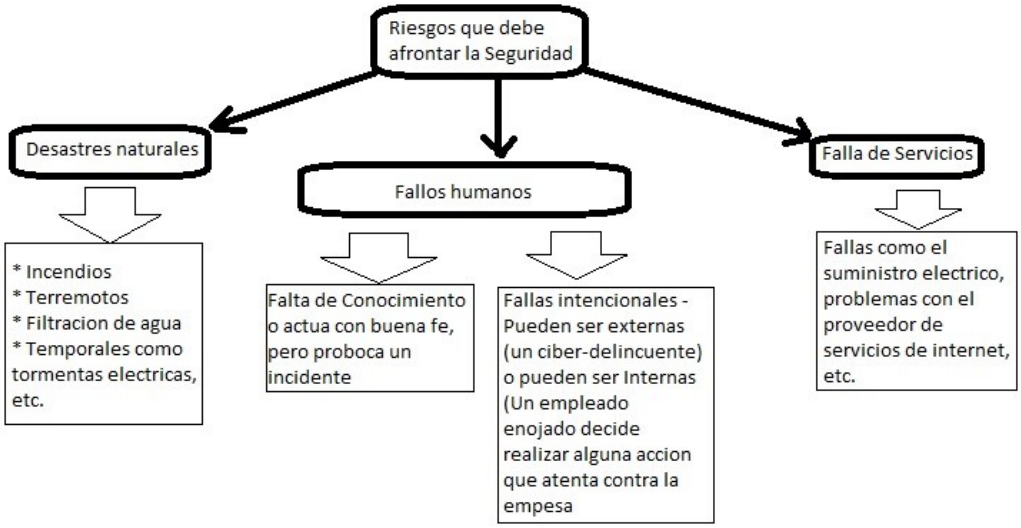

Fig. 10 – Imagen de Diagrama de Riesgos que afronta la Seguridad Informática

Luego realizará una evaluación de los riegos, siendo así la identificación de éstos en primer lugar, el impacto y la probabilidad de que pueda ocurrir, jerarquizar y dar prioridad en el tratamiento de dichos riesgos. El paso siguiente es establecer el tiempo máximo que la empresa podría permanecer con la interrupción de servicios y/o procesos críticos.

Como ocurre en cualquier accidente en la realidad, se hace imprescindible asignar roles y tareas específicas, con sus correspondientes obligaciones, al personal en caso de una emergencia.

Es importante que lo anteriormente expuesto sea correctamente documentado, en un lenguaje que sea entendible y sencillo.

Luego de hacer frente a una amenaza la cual se tenga poca información, es interesante documentar también, en un informe sencillo en el cual se detallen los datos más relevantes, estos podrían ser fecha en la que ocurrió el incidente, tiempo aproximado desde que se hizo efectivo el incidente y el tiempo en el cual se pudo restablecer el funcionamiento normal, además especificar los pasos que se usaron para resolver el incidente.

Estos datos son interesantes ya que sienta un precedente y una posible forma de resolverlo, pudiendo estimar el tiempo que llevó hacerlo.

Se ve necesario aclarar que el plan de contingencia no es perdurable en el tiempo, sino que se debe someter a revisión y correcciones futuras en conjunto a la documentación realizada y a las experiencias pasadas.

En cuanto a la recuperación de datos, es importante dar algunas ideas o recomendaciones que, a pesar del paso del tiempo, nuevas tecnologías y otros factores, este punto queda olvidado muchas veces, y por más que podamos diagnosticar, poseer medidas preventivas y de detección, si esto no es suficiente y no se cuenta con los medios apropiados para recuperarnos de un incidente informático, todo lo anteriormente mencionado no valdrá de nada.

Muchas veces, es normal encontrarse con las personas que preguntan "¿Es necesario tener una copia de seguridad?" "¿Cuántas veces tengo que hacer una copia de seguridad?", etc.

Lo primero es dar una breve introducción, un backup / copia de seguridad / respaldo es aquel proceso que permite realizar una copia de los archivos más importantes para poder ser recuperados en caso de sufrir un incidente informático. Así mismo no toda la información es de vital importancia, por lo cual se debe seleccionar cuidadosamente qué información se deberá resguardar.

La realidad es que depende de varios factores. Primero, se debe ser consciente que con hacer copia de seguridad una vez a la semana como mínimo podría bastar, en realidad esto se relaciona con la cantidad de información que genera o utiliza la empresa. Si la información es crítica, por ejemplo, en una empresa donde el punto fuerte es el comercio electrónico, se debería tomar la medida de todos los días, después del horario laboral, realizar una copia de seguridad.

En algunas ocasiones es mejor realizar copias de seguridad con diferencia de dos o tres días, recordar que una copia de seguridad también exige un cierto espacio, si bien hoy en día el espacio no es un problema, si se tiene un equipo sobrecargado de copias de seguridad, podría afectar en distintos sentidos a dicho equipo.

Hay diferentes formas de realizar una copia de seguridad, existen diferentes herramientas gratuitas y pagas, las cuales brindan distintos servicios.

Existe la opción de copiar los archivos sencillamente y pegarlos en algún medio externo, sea este un cd/DVD/pendrive/disco externo u otro dispositivo. Aquí es importante saber que, dependiendo el medio, la duración de la información dentro de ellos, puede varias.

Además, se debe tener en cuenta que, si uno hace una copia de seguridad, el medio debe extraerse de los equipos, ha habido casos en los cuales se guardan las copias en un disco externo, éste queda conectado y al momento que la empresa sufre un incidente, la copia también se ve afectada y se pierde, también existen casos en los cuales se realizan la copia queda en los mismos equipos, sin saber que esto es lo mismo que no se hicieran copias en caso de un ataque de virus u otras amenazas.

Es importante saber qué es lo que es necesario realizar copias de seguridad, por ejemplo, si se usa un motor de base de datos como SQL Server, hay varias alternativas externas al motor que pueden programarse copias, pero si contamos con un motor completo, éste incluso tiene la opción de realizar un plan de mantenimiento el cual se pueden generar copias de seguridad.

Existen tres tipos de copias de seguridad que se pueden evaluar al momento de implementar este tipo de procesos.

Tipo de seguridad Completa:

Este tipo de copias, comprende la totalidad de la información a resguardar, el cual para un inicio es una buena opción, pero al pasar el tiempo, se debería cambiar de opción.

Tipo de seguridad Diferencial:

Este tipo de copia permite verificar los cambios que sufren los archivos en el sistema desde la última vez que se realizó una copia de seguridad completa, tienen la posibilidad de ser acumulativas, es decir que no reemplazan las copias anteriores y cada copia se realiza, respalda la información diferente que hay en la anterior copia.

Tipo de copia Incremental:

Similar al anterior, solo que este tipo de copia solo hace una copia desde la última copia de seguridad diferencial o incremental, haciendo dicha copia con menor cantidad de datos. Se recomienda realizar en un equipo de prueba, restaurar con frecuencia las copias de respaldo realizada para garantizar su correcto funcionamiento.

Tipos de copias	Ventajas	Desventajas
No realiza copias de seguridad		En caso de un incidente informático, se pierden todos los datos sin posibilidad de recuperarlos
Completa	Posibilidad de recuperar los datos luego de un incidente informático.	Requiere realizar la copia completa, y no importa si ya están repetidos los datos. El tiempo que se tarda en hacer la copia es mucho mayor, aún con datos que no han sido modificados. Se requiere de mucho espacio de almacenamiento.
Incremental	Se reduce el tiempo de copia. Se reduce el espacio utilizado, gran diferencia con la copia completa o diferencial.	Tiempo de restauración más lenta y complicada que en los otros dos tipos de copia. Depende de la copia completa y las incrementales anteriores. Si falla cualquiera de las copias dependientes, no se podrán restaurar las copias
Diferencial	La copia de datos más ágil y veloz que la copia completa. Menor espacio requerido para almacenar las copias que una copia completa. Solo depende de la última copia completa, por lo cual es un poco más fiable.	Recuperación de datos más lenta que las otras dos opciones, debido a que primero, se debe recuperar una copia completa y luego la diferencial. Si falla la copia diferencial o completa no se restauran datos. Hay datos duplicados entre las copias diferenciales pues cada copia diferencial almacena todas las modificaciones realizadas desde la última copia completa. Si el tiempo entre las copias completas y diferenciales es muy grande, el espacio requerido para este tipo de copias seria casi lo mismo que una copia completa.

Tabla 1 – Ventajas y desventajas de los tipos de copias de seguridad.

Capítulo V - Desarrollo

A continuación, se presenta una guía de buenas prácticas de seguridad Informática, elaborada a partir de análisis y distintas alternativas para hacer frente a distintas amenazas. Esto es, haciendo un análisis y un diagnóstico de las redes, configuraciones diversas, tanto de software como de hardware de los equipos de la empresa. Y luego realizar una metodología para afrontar algunos de los incidentes más comunes que puede presentar tal entidad y desarrollar un conjunto de políticas de seguridad para poder defenderse de las amenazas Informáticas.

Es muy habitual en las organizaciones el planteo sobre "construir" una línea de defensa. Pero si solo planteamos una línea de defensa, o concentramos todos nuestros esfuerzos en un punto, por ejemplo, fortaleciendo solo aquel pc que se utiliza como Servidor (sea servidor porque brinda uno o varios servicios al mismo tiempo) entonces estaríamos cometiendo un error grave.

"Si los activos no están bien protegidos. Si la penetración continua puede resultar en gran riesgo financiero. Si no existe la posibilidad de perseguir al intruso. Si los usuarios no poseen conciencia o experiencia sobre la seguridad y los recursos que peligran. Si no se posee evidencia concreta y contundente ante una acción judicial. Si recursos no están claramente establecidos o identificados." – La mejor estrategia es Proteger y Proceder – [3]

Esta estrategia a tener en cuenta no requiere de un alto grado de capacitación, ni recursos exageradamente grandes para una PyME.

Las PyMEs son un objetivo tentador para cualquier cibercriminal con algo de experiencia en estos temas, las razones son variadas, pero el caso es que, como protectores de la información de nuestra empresa hay que estar preparados. Las cuales fueron descriptas en la sección de "Marco Teórico".

Casos prácticos

Luego de tener algunas definiciones y la teoría planteada, se procede a realizar casos supuestos teniendo en cuenta los distintos tipos de PyMEs y cómo se debe proceder con ellas. Es importante poder definir con un cierto orden para los tipos de PyMEs que se pueden encontrar, para tal propósito, se procede a identificar los tipos de empresa con la referencia que brinda la Administración Federal de Ingresos Públicos (AFIP), en relación al personal y ventas totales anuales. Cabe aclarar que hay distintos sectores, para delimitar y a modo de ejemplo que nos permita aplicar la teoría antes expuesta, nos centraremos en el sector de Comercio como se presenta a continuación.

Actividad Comercial

Categoría	Ventas totales Anuales	Personal ocupado
Micro	23.560.000	7
Pequeña	141.680.000	35
Mediana - Tramo I	1.190.400.000	125
Mediana - Tramo II	1.700.590.000	345

Tabla 2 – Categorías de PyMEs

Según la categoría de las PyMEs, se podrá o no aplicar algunas estrategias para defenderlas sobre diversos incidentes.

Como norma general, es importante actualizar los sistemas operativos, instalar una solución antimalware, protección en los correos electrónicos, catalogar/clasificar su información y poseer algún tipo de plan de contingencia y tener las licencias para el sistema operativo y otros programas como el paquete office, etc. A su vez se debe tener en cuenta la posibilidad de brindar al menos tres alternativas dividas en “Alternativa Básica, Alternativa media y Alternativa alta”.

Para catalogar la información, hay tres aspectos que se ha visto anteriormente, el concepto 'CIA', es decir Confidencialidad, Integridad y Disponibilidad.

Es común que solo se tenga en cuenta una de estas tres dimensiones, generalmente se hace énfasis en el aspecto de Confidencialidad.

Aunque dependiendo a que se dedique la empresa es a qué dimensión le dará más importancia, por ejemplo, para una PyME que su fuerte es la venta de artículos mediante una Página web, quizás sea más importante la Disponibilidad de dichos servicios. Si es una entidad financiera quizás sea más importante la Integridad, por las transacciones bancarias. Por ende, depende de a que se dedique el negocio para poder realizar una mejor catalogación de información y dar la prioridad adecuada.

En una PyMEs de categoría micro hay un flujo de información mucho menor a los demás tipos de PyMEs, aun así, se deben tomar los recaudos necesarios para que estas no se vean afectadas, o si lo son, el impacto sea mucho menor.

Aplicando los conocimientos teóricos anteriormente expuestos. Aunque sea un entorno pequeño, es muy probable que se trabaje con “Grupo de trabajo” las cuentas de Administrador deben ser deshabilitadas y crear al menos una cuenta estándar. Es importante recordar configurar el Control de Cuentas de Usuarios, acorde al negocio. Luego se prosigue con las recomendaciones de cómo crear una contraseña robusta, instalar algún antivirus freeware. En lo que respecta a amenazas Naturales, son iguales para todos los tipos de PyMEs, una inundación puede afectar tanto a una PyME micro como a una gran empresa.

El cableado debe prestarse atención por la razón que, si el lugar hace operaciones vía internet, pero el cableado de datos no tiene un cuidado apropiado, tarde o temprano, éste no funcionara correctamente y nos es probable que la empresa no tenga servicio de internet.

Las amenazas humanas, son básicamente las mismas, pero una PyME pequeña no tiene quizás el capital o no se justifica invertir en un lector de huellas digital, pero hay otras medidas básicas a implementar. En este tipo de PyMEs pareciera ser más frecuente que las amenazas provienen del exterior, pero tomar algunos recaudos para dentro de la misma empresa, como es el caso de las cuentas de usuario limitadas, así se puede establecer una barrera a aquellas personas internas que atentan contra la seguridad.

En tipos de PyMEs Micro:

Este tipo de PyMEs tiene dos aspectos que hacen una tarea difícil de mejorar su seguridad. En primer lugar, es que poseen poco presupuesto para invertir en muchas actividades, entre ellas la seguridad propiamente dicha de los activos de información que estas utilizan.
El otro aspecto es variable ya que se trata de la información que utiliza o procesa. Si es una empresa micro es muy común que solo utilice programas como Word, Excel y no tenga toda la información digitalizada, además que es poco probable que tengan programas de otra índole como un Programa Enlatado, es decir, un software genérico que cumple con las necesidades de un área determinada. (aunque existen casos que poseen este tipo de software instalado).
Por lo cual, es poco probable que justifiquen el "gasto" de implementar seguridad en un entorno así, pero es una verdad que deben de ser consciente que pueden ser víctimas por distintas razones de un incidente informático y no tiene que ver necesariamente con ataques de ciber-delincuentesncuentes.

Alternativa Baja:

Estas PyMEs de este tamaño, suele ser habitual que no puedan afrontar una inversión para fortificar la seguridad con todas las herramientas disponibles, o contratar un servicio para que puedan evaluar y dar un reporte de la situación actual de su empresa y su solución. Pero pueden realizar algunos procedimientos y configuraciones básicas que podrán hacer frente a distintas amenazas.
En primer lugar, como base en todo ámbito de trabajo, se define la forma de trabajo, como se mencionó anteriormente, en la familia de Microsoft solo hay dos alternativas, para una PyME de tamaño micro, al ser muy pocos equipos los cuales funcionan, es recomendable que sea bajo Grupo de trabajo. Se debe recordar que este tipo de PyMEs, por su naturaleza, es muy común que utilicen no más de diez equipos, por lo que un grupo de trabajo es apropiado para este escenario.
Aunque se trate de una PyME la cual no posee demasiados usuarios, aun así, se debe respetar el concepto de mínimos privilegios, los suficientes para que cada usuario pueda realizar su trabajo sin que interfiera con éste.

Por lo tanto, se debe crear cuentas de usuario estándar, limitadas acorde al trabajo de cada usuario, para aquellos que sean encargados, darles algo más de privilegios, pero la cuenta Administrador, salvo por excepciones, se debe proceder a deshabilitar como se ha indicado.
A su vez, se debe definir qué usuarios tienen permiso para usar / leer / modificar / escribir archivos, carpetas o incluso recursos de red como pueden ser impresoras.
Seguido de dar los pertinentes permisos a cada usuario, sigue la configuración de Control de Cuentas de usuario que nos ofrece Microsoft. Ya que estamos en un escenario de trabajo, se recomienda utilizar la era opción “Notificarme cuando una aplicación intente realizar cambios en el equipo”.
Con el fin de evitar algunos problemas, mediante el editor de directivas de seguridad local, existe la posibilidad de definir en cada usuario algunas tareas que pueda o no realizar como la ejecución de programas, el cierre de sesión automático luego de finalizada la jornada laboral, etc.
Es importante realizar la selección del método de autenticación, debido a los tiempos que transcurren, seguramente se utilizara el método de contraseña, recordar aquellas recomendaciones descritas con anterioridad, como lo son la limitación de intentos para ingresar la contraseña correcta, la longitud y requerimientos mínimos de ésta.
Para esta instancia, se debe chequear que servicios iniciara cada equipo, y si conviene o no deshabilitar aquellos que no se utilicen o no se piensen utilizar, por ejemplo, si en una empresa de este calibre no se piensa imprimir bajo ningún punto de vista y queda establecido de esta manera, lo mejor sería deshabilitar el servicio de cola de impresión.
Siguiendo con las recomendaciones, recordar que hay programas que por defecto se pueden ejecutar, si bien algunos son una herramienta fundamental para el trabajo de la persona que se encarga de la parte de sistemas de la empresa, un usuario común no debe por qué utilizar por ejemplo la consola de comandos para realizar las tareas que le corresponden (Igualmente, antes de aplicar restricciones, es recomendable hablarlo con la gerencia de la empresa y explicarle a los usuarios que riesgos conlleva tener este tipo de programas habilitados).
Se hace necesario en estos tiempos, implementar al menos un antivirus que cumpla con las necesidades básicas del negocio.

En esta instancia no es necesario que sea licenciado, se puede utilizar un antivirus gratuito, hay muchos que ofrecen un buen servicio, aunque éstos sean gratuitos, así también se recomienda utilizar algún firewall que pueda ayudar a monitorizar el tráfico y así reducir la posibilidad de ataques a los cuales está expuesta la empresa.

Uno de los temas que llaman la atención en cuanto a la gestión de un router/Switch que poseen las empresas, son dos cuestiones, la primera es que en muchos casos, se deja el usuario y contraseña de aquel router que es entregado por el proveedor de internet o aquel Switch adquirido por una compra, esto realmente es un error, se debe ser consciente que aquella persona que tenga algo de conocimiento, y pudiendo acceder a la red de la empresa, puede simplemente ingresar al dispositivo y observar por ejemplo la cantidad de usuarios conectados, o el simple hecho de cambiar la contraseña de la red wifi, en caso que el negocio tuviera alguna red de esta índole y así dejarlos sin acceso. Usualmente, el usuario y contraseña pueden ser admin/admin o variantes, de acuerdo al modelo. Por eso, como se mencionó antes, es recomendable que se dé una apropiada configuración a los dispositivos de red antes de que sean utilizados, bajo ningún punto de vista puede darse el caso de "sacarlo de la caja y conectarlo para su funcionamiento".

Estas clases de PyMEs no cuentan con la digitalización de toda la información. Por lo tanto deben prestar atención a aquellas amenazas de índole natural como las amenazas Informáticas, hay casos donde la empresa tiene archivado varios papeles en una caja de cartón en un lugar donde es fácil la filtración de agua o puede inundarse, o es propenso a un incendio, por más trivial que parezca, se deben observar y tomar acción para que esta información tampoco se pierda, en el caso de los equipos informáticos, en esta instancia es recomendable que al menos se haga un chequeo del estado de la red eléctrica para estar seguros que ésta no genere algún incendio, poniendo en peligro la seguridad de las personas y de la empresa en general. Con respecto a la forma de recuperar su información luego de un incidente informático, lo mejor es conseguir algún software el cual permita agilizar el proceso de gestionar copias y a la vez recuperar la información.

Alternativa Alta:

Para esta alternativa, se aplica la base de la anterior propuesta, realizando algunas modificaciones.

Se sigue definiendo como forma de trabajo el Grupo de trabajo, porque la naturaleza de la PyME no cambia y la cantidad de equipos no suele variar de la anterior alternativa.

En esta alternativa también se debe respetar el concepto de mínimos privilegios, los suficientes para que cada usuario pueda realizar su trabajo sin que interfiera con éste. Por lo tanto, se debe crear cuentas de usuario estándar, limitadas acorde al trabajo de cada usuario, para aquellos que sean encargados, darles algo más de privilegios, pero la cuenta Administrador, salvo por excepciones, se debe proceder a deshabilitar como se ha indicado.

También se debe mantener la definición de qué usuarios tienen permiso para usar / leer / modificar / escribir archivos, carpetas o incluso recursos de red como pueden ser impresoras.

El Control de Cuentas de usuario que nos ofrece Microsoft. Ya que estamos en un escenario de trabajo similar al anterior, se recomienda utilizar la era opción “Notificarme cuando una aplicación intente realizar cambios en el equipo”.

Se debe utilizar el editor de directivas de seguridad local, es factible definir en cada usuario algunas tareas que pueda o no realizar como la ejecución de programas, el cierre de sesión automático luego de finalizada la jornada laboral, etc.

Se utilizará el método de contraseña, recordar aquellas recomendaciones descritas con anterioridad, como lo son la limitación de intentos para ingresar la contraseña correcta, la longitud y requerimientos mínimos de ésta. Como en la anterior alternativa.

Los servicios de cada equipo deben revisarse también en esta alternativa, pero con más rigurosidad.

Al igual que en la anterior alternativa, hay programas que por defecto se pueden ejecutar, si bien algunos son una herramienta fundamental para el trabajo de la persona que se encarga de la parte de sistemas de la empresa los cuales deben ser revisados.

Se debe implementar un antivirus que cumpla con las necesidades básicas del negocio. Hay opciones gratuitas, pero para esta alternativa se recomienda pagar una licencia para tener acceso a otros módulos que de forma gratuita no se tiene acceso, esto difiere según la firma de la solución de antivirus que se contrate, la misma lógica aplica para la adquisición de licencias de antivirus (Como se menciona anteriormente, se debe revisar que módulos traen los antivirus con el pago de licencias ya que algunos ya cuentan con el módulo de firewall).

En esta alternativa también aplica la lógica de cambiar el usuario y contraseña por defecto de los dispositivos de red implementados. Con respecto a la seguridad física, se puede implementar la colocación de cámaras IP (son más económicas y brinda la facilidad de que pueden consultarse desde cualquier lugar) para que se pueda tener alguna vigilancia en nuestros equipos, a su vez, se puede implementar también sensores de movimientos conectados a una alarma, esto proporciona una seguridad general a la empresa contra destinos problemas. Si se implementan cámaras IP se recomienda verificar el acceso al dispositivo y cambiar los parámetros por defecto, ajusticio así a las necesidades de la empresa e impidiendo problemas futuros. Con respecto a la forma de recuperar su información luego de un incidente informático, lo mejor es conseguir algún software el cual permita agilizar el proceso de gestionar copias y a la vez recuperar la información. Es importante mencionar que en esta alternativa se piensa en implementar todo el software licenciado en la medida que el presupuesto lo permita, así se puede contar con el soporte de las distintas herramientas y las actualizaciones correspondientes. Otro punto en esta alternativa, es que al menos, la parte de la gerencia de la empresa, pueda realizar las consultas necesarias o realizar alguna capacitación con respecto a los temas que implica la seguridad Informática en este tipo de empresas.

En tipos de PyMEs Pequeña:

Alternativa Baja:

En PyMEs de tipo Pequeña aún se pueden seguir utilizando la forma de trabajo de Grupos de trabajo, pero el tamaño puede acceder a más de treinta equipos haciendo difícil quizás la administración y gestión de los mismos, aun así, en esta alternativa es factible seguir trabajando como Grupo de trabajo. Se debe tener en cuenta siempre el concepto de mínimos privilegios de usuarios, los cuales ya se han definido, pero con mayor rigurosidad, teniendo en cuenta el organigrama de la empresa, facilita la tarea del armado de los privilegios o permisos para acceder a los recursos compartidos, carpetas, archivos y en relación a los usuarios definidos, ya con un esquema como guía facilita dichas tareas. El Control de cuentas de usuario por ahora es posible dejarlo activado en la misma opción que en las alternativas anteriores. La edición de las directivas de seguridad, deben ser revisadas mensualmente, y coordinar con la gerencia para realizar los ajustes pertinentes.

El método de autenticación no debería varias, si este es el caso, se deben seguir las recomendaciones ya indicadas. Se debe realizar el mismo proceso de revisar los servicios y programas utilizados para minimizar riesgos. Con respecto a los antivirus y los firewalls se deben llevar a cabo las configuraciones pertinentes, se recomienda debido a la envergadura de estas empresas, que los programas utilizados se adquieran las licencias correspondientes. No se debe olvidar las configuraciones y las recomendaciones de los dispositivos de red como se ha visto antes.

Con respecto a los planes de contingencia, se deben planificar y llevar una revisión mensual rigurosa, además que en este nivel se requiere algo más que un simple software que genere una copia automática de la información, se debe garantizar que dicho respaldo es funcional y pensar otras alternativas como puede ser contratar un servicio externo a la empresa para el resguardo de la misma.

Alternativa Alta:

Realizando aquellos procesos que son como la base para fortificar nuestra empresa, como los permisos de usuarios, archivos, carpetas compartidas, la configuración del control de cuentas de usuario, llevar a cabo las recomendaciones de una contraseña, verificar las directivas de seguridad, los servicios de cada equipo y de los dispositivos de red, un buen inicio es comenzar con la inversión de un antivirus licenciado a nivel empresarial, el cual nos permite ayudar a gestionar algunas soluciones contra diversas amenazas, agregando más funcionalidades, como por ejemplo, eliminar archivos ocultos o no deseados, adquirir un mayor control en el firewall integrado aplicando filtros para poder monitorizar la red y detectar anomalías en ella.

A nivel de red se pueden implementar redes privadas virtuales (Vlans) si se poseen switches administrables, para cada sector, por ejemplo una Vlan para el sector de ventas, otra para el sector de gerencia y así subdividiendo la red, ayudándonos con el organigrama de la empresa, es claro que nos permite una mejor organización de la red a nivel general, también brinda mayor escalabilidad, es decir, mayor facilidad de crecimiento de la red y para finalizar nos brinda mayor seguridad, haciendo así que los dispositivos vinculados a una Vlan no tienen acceso a los dispositivos que se encuentren en otras redes y viceversa, lo que refuerza la confidencialidad.

Se pueden aplicar algunas restricciones más que en una PyME micro como por ejemplo el uso de pendrives personales o sin autorización pertinente para evitar que los equipos sean víctimas de distintos tipos de malware o spyware.
Adicionalmente se pueden implementar medidas con respecto al suministro eléctrico, invirtiendo en estabilizadores, si la empresa utiliza servidores, es recomendable que estos, tengan conexión a un UPS, así si hay algún corte del suministro de energía, tenemos un determinado tiempo para apagar los servidores de forma natural y no tengan algún daño posterior.
También verificar las conexiones eléctricas y el pasado de cables de red, lo ideal sería embutidos y que cada medio está separado, es decir realizar el entubamiento de los cables de datos y aparte otro entubamiento pero que corresponda a la red eléctrica, así se podrá preservar ambos medios, sin que existan inferencias ni otros daños.

En esta situación se hace forzoso pensar en un plan de contingencia, el cual pueda quizás es recomendable que en esta instancia sea un producto pago, siendo una herramienta automatizada o bien se recomienda un servicio que esté alojado en la nube para resguardar la información en la web, en principio parecería ser un gran gasto, pero evidentemente es una buena inversión a futuro cualquiera de las dos alternativas. Aquí se pueden encontrar entornos que trabajan por medio de grupo de trabajo, pero también se pueden comenzar a implementar dominios porque poseen uno o varios servidores (sea el servicio que este provea) debido al posible crecimiento de la red, por ende, más equipos, y es más sencillo gestionarlos mediante dominio. Si este es el caso hay que recordar dar de baja los servicios que no son utilizados.
Además, aquí se puede comenzar a plantear el uso de equipos especializados en firewall para fortalecer la seguridad de la red, también implementar un cambio en la forma de trabajo y usar Dominio en vez de grupo de trabajo con la debida configuración de un servidor que gestione las cuentas de usuarios y otros servicios, esto hace que se le dé especial énfasis a buscar y desactivar aquellos servicios que no son utilizados. Al tener un esquema de trabajo de este estilo se puede configurar la generación de logs y utilizar el visor de eventos para monitorear si detectamos alguna anomalía.
También es factible implementar algunas cámaras de video vigilancia si se cuenta con un pequeño sector para los equipos informáticos previamente descritos.

Los lugares donde estarán alojados los equipos servidores, firewalls físicos y otros dispositivos, deben ser en lo posible en un lugar resguardado de las distintas amenazas naturales, ya descritas en los conceptos de Seguridad Física.
En relación a los planes de contingencia, se debe contar con herramientas más avanzadas y en lo posible, autónomas y de confianza.

En tipos de PyMEs Mediana - Tramo I y Tramo II:

Debido a la gran cantidad personas que hay en estos tipos de PyMEs y al presupuesto que pueden utilizar, pueden estar mejor preparados para las distintas dificultades que deben afrontar.
Pero estas empresas tienen otra cara de la moneda, en varias firmas de Antivirus (Por citar ejemplos: Kaspersky, Avast, Panda Security, Eset, etc.) y varios profesionales en el tema, indican que más de 55% de las empresas no invierten en seguridad hasta que no sufren un incidente informático grave. Por lo tanto, hay muchas empresas de este tipo que hasta que no se ven afectadas, no invierten en seguridad, para algunas, nunca llega este momento, ya que como se mencionó antes en un periodo de seis meses aproximadamente, la empresa tiene un final abrupto.

Alternativa Baja:

Para el tipo de PyMEs de estas características, se hace obligatorio cambiar la forma de trabajo, para empresas entre 125 – 345 empleados, si bien no todos estarían trabajando por medio de una PC (todo depende de la empresa), pero suponiendo que tengan alrededor de 40 PC ya es demasiado para gestionar y administrar con grupo de trabajo, aunque se subdividen en otros grupos de trabajo, no es la forma o mejor dicho, no es lo más conveniente por diversas razones que tienen que ver con el mantenimiento y con la configuración de usuarios. Por lo tanto, estas alternativas sólo dan lugar a trabajar como Dominio. Este hecho hace pensar que entonces se debe implementar un servidor, en el cual se pueda gestionar las cuentas de usuario y además tiene la ventaja que, si los mismos trabajan propiamente en un servidor de aplicaciones, hace que los recursos que utilicen sean los del servidor, y es más sencillo detectar un problema en principio.

Los privilegios de usuarios, la definición de directivas de seguridad, los permisos a archivos, carpetas y recursos compartidos requiere un análisis y estudio previo antes de implementarlas. Con respecto a las contraseñas, gestión de dispositivos de red y otros, aplica de igual manera que las PyMEs de menor tamaño, pero en este tipo de escenarios requiere que los tiempos se acorten o sea más riguroso el monitoreo. En una PyME de estos calibres, no está mal pensar quizás hacer que cada mes se actualicen las contraseñas, o, por ejemplo, que en vez de tener cinco intentos de logueo en la cuenta y luego se bloquee, que, en estos escenarios, sea como mucho dos intentos. Es un punto difícil de llevar a cabo ya que hay que equilibrar la seguridad con la comodidad de los usuarios, y a veces se torna demasiado compleja la situación.

Hay muchas empresas de este tipo, que los servicios quedan sin atención, entonces se llega a encontrar una empresa con cien PC funcionando y cada una con todos los servicios activados, servicios que quizás sean inofensivos, pero el atacante encuentra la forma de encontrar alguna vulnerabilidad y así realizar un desastre en la empresa.
Si se pretende utilizar algún software como antivirus o firewalls gratuitos, particularmente, en esta instancia no es garantía de nada, muchas veces se cree que por tener un antivirus la situación está resuelta, pero no es así, para este tipo de PyMEs es mejor realizar una compra de licencias a nivel empresarial, hay que hacer la gran diferencia entre un antivirus de una marca de renombre y un antivirus poco conocido, puede que este último sea más barata la licencia, pero el riesgo puede incrementar debido a factores como la base de virus que utilice la empresa, la capacidad de análisis y otros factores, para un PyME Mediana de Primer tramo, puede ser factible implementar un antivirus de forma alternativa, pero una mejor elección es elegir un antivirus que esté reconocido, y a su vez realizar las configuraciones pertinentes, si es necesario, ponerse en contacto con el soporte de la firma de antivirus contratada para disipar las dudas que se tengan. Lo mismo aplica a los Firewalls, aunque un detalle es que se puede implementar un firewall de forma física y/o firewall de software, todo depende como se va a monitorear la red.

Al tener un organigrama seguramente más grande que los otros tipos de PyMEs anteriores, es necesario realizar la construcción de la infraestructura de la red con Vlans, de ser necesarios, identificándose con cada sector de la empresa para mejor administración.
En estos dos tipos de PyMEs se deberá contratar personal de seguridad para monitorear la entrada y salida de personas, llevando un registro de las mismas.
Se hace necesario en las PyMEs de Medianas de tramo 1 que la capacitación del personal de sistemas sea competente al nivel requerido, siendo optativo la capacitación de la parte gerencial de la empresa, para una mejor respuesta ante incidentes informáticos.

Alternativa Alta

Como alternativa alta, se aplica todas las recomendaciones hechas en la alternativa anterior, pero con las siguientes diferencias y/o agregados pertinentes. La UAC debe estar en la opción máxima. El antivirus y firewall implementados deben ser de firmas conocidas, ya no pueden ser de firmas alternativas, comprando las licencias necesarias con el plan más completo posible.
Se hace imprescindible el hecho de utilizar o bien un Sistema de Detección de Intrusos (IDS) o bien un Sistema de Prevención de Intrusos (IPS) – se recuerda brevemente, un IDS solo alertará de alguna anomalía que detecte, según su configuración y los patrones que pueda identificar y un IPS sencillamente actuará en ese momento de forma proactiva. Realmente es una ventaja tener implementado alguno de estos sistemas, si nuestro IDS/IPS tiene configurado o identificado un patrón, firma lo algo que identifique por ejemplo un Ransomware, entonces, éste o emitirá alguna alerta al administrador de sistemas para que él realice alguna acción, o bien, si es un IPS puede directamente desconectar al host infectado, salvaguardando el resto de la red y así la empresa.
Además, implementar sensores de movimientos en todos los pisos que cuenten con equipos y sala de servidores e implementar cámaras de seguridad de circuito cerrado, tanto dentro como fuera del edificio de la empresa.
En las empresas Medianas de tramo II se recomienda altamente implementar Control de acceso por medio de huella digital, haciendo así una distinción del personal autorizado para las áreas que le corresponden según el nivel de responsabilidad dentro de la empresa. Adicionalmente es necesario implementar logs que nos ayuden a revisar actividades sospechosas en nuestros equipos de trabajo o servidores.

La capacitación debe hacerse a todos los niveles, comprometiendo a todas las áreas, es decir, la gerencia y el personal de sistemas sean correctamente capacitados, bien por el propio personal de sistemas, o bien por una empresa o persona externa a dicha empresa.

En esta instancia es fácilmente reconocible que se necesitan los medios necesarios para poder garantizar de la mejor forma los recursos, esto es, poseer redundancia en los servicios como, por ejemplo, internet, la red eléctrica y otros. Si es posible implementar grupos electrógenos para hacer frente a un corte de luz por ejemplo, o bien si se tiene la posibilidad, contratar más de un proveedor de internet, podemos decir que dependiendo el escenario, pueden o no ser opciones factibles, pero brindan alguna idea que pueda ayudar a evitar que la empresa se quede sin recursos para seguir operando con normalidad.

Capítulo VI - Conclusiones

Gracias a la elaboración de este trabajo, se pueden formular varias conclusiones. Primero que asegurar cualquier empresa, requiere mucho tiempo, leer varios artículos y en base a eso y al entorno que se tiene, diseñar la mejor forma de defender la organización.

En segundo lugar, la Seguridad Informática es un gran rompecabezas que todas las piezas están íntimamente relacionadas entre sí. Es realmente importante capacitar al personal de Sistemas, pero a su vez es importante capacitar a todas las áreas involucradas y que las partes posean una buena comunicación entre sí.

Se hace complejo para las PyMEs de hoy día hacer frente a un “gasto” con respecto a estos temas, pero hay que entender que en realidad es una inversión a futuro la cual garantiza que se pueda estar mejor preparado para los incidentes informáticos, y en caso de sufrir algún incidente, poder recuperarse en el menor tiempo posible y así la empresa no se verá afectada. En tercer lugar, es importante que todo acceso o modificación sobre el hardware quede reflejado de alguna forma para que pueda ser comprobado posteriormente en el supuesto de fallos o problemas de funcionamiento del sistema.

También hay que recalcar que las ideas sobre las medidas que se vayan a implementar para asegurar los sistemas, sea física y lógicamente, pueden chocar frontalmente con las prácticas habituales de la empresa, se debe dar un balance entre comodidad y seguridad, ya que, si esto no ocurre, bien podemos tener graves problemas de seguridad, o bien, podemos hacer que nuestras propias medidas atenten contra las reglas del negocio.

En cuarto lugar, para que la empresa pueda tener un proceso de seguridad correcto, es imprescindible comprender que la seguridad lógica y la seguridad física se complementan entre sí y no puede dejarse ninguna de estas dos olvidadas.

En quinto lugar, se hace necesario desarrollar un plan de contingencia ante incidentes informáticos, o al menos, como mínimo se debe implementar algún mecanismo que permita a la empresa recuperarse de un incidente.

Definir permisos a usuarios, carpetas, archivos y recursos compartidos es un buen comienzo para evitar amenazas como el malware y otros programas maliciosos, definir lineamientos básicos de contraseñas para hacerlas lo más robustas posibles, revisar cuidadosamente los servicios que se ejecutan, y configurar y tener en claro todo lo antes dicho sobre mínimamente firewalls y antivirus, si la empresa puede implementar un IDS/IPS sería lo ideal ya que pueden complementarse muy bien con otras soluciones enfocadas en defender la empresa.

Capítulo VII - Líneas de Trabajo a futuro

Tema RAIDS - En servidores importantes, tener un sistema que pueda grabar en dos discos simultáneamente es una buena idea para respaldar datos y en caso de que hubiera algún problema, el usuario no pasaría mucho sin poder volver a trabajar como habitualmente lo hace, este tema no se incluyó en los alcances de este trabajo

Tema Virtualización - Los servidores que puedan ser virtualizados, tiene varias ventajas, entre ellas el hecho de poseer una sola PC con los requerimientos correspondientes, nos ahorra mucho costo en insumos, además otras posibilidades. Inicialmente no se tuvo en cuenta este escenario, por esa razón no se llevó ninguna investigación a cabo, pero es un buen punto de partida para próximos trabajos.

Tema Windows Server - Algunas empresas optan por trabajar con la familia de Windows server, en conjunto con la forma de trabajo de dominio (en vez de grupo de trabajo) y utilizando Active Directory se puede gestionar fácilmente varias cuestiones administrativas, en diferentes fuentes de información, hay abundante información, en el este trabajo se plantea una pequeña introducción, no se incluyó en su totalidad este tema en los alcances del trabajo.

Tema Seguridad en dispositivos móviles - Con excepción de las empresas Micro, es recomendable atender estos dispositivos ya que son una opción viable si se quiere comprometer los equipos de una empresa. Este tema no se incluyó en los alcances de este trabajo.

Tema Honeypot y Honeynet - Son herramientas dispuestas para que en una red o sistema informático sean objetivo de un posible ataque informático, y así poder detectarlo y obtener información del mismo y del atacante. En el alcance del trabajo no fueron incluidas.

Anexo A

Cuentas de usuario:

Para eliminar una cuenta por ejemplo seguir los siguientes pasos:

1) Clic derecho en Equipo ->Administrar

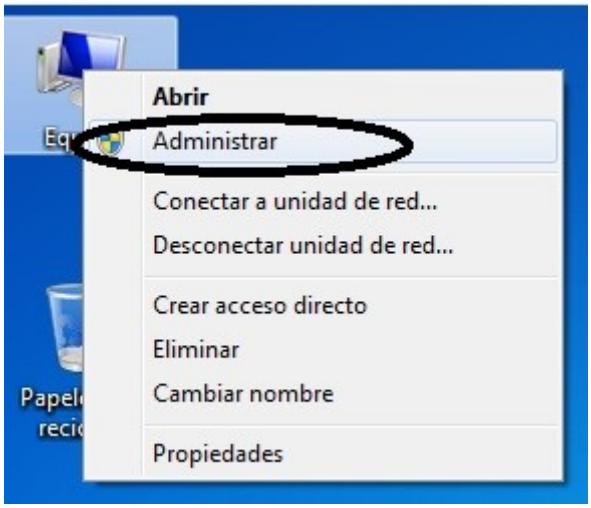

Fig. 1 – Imagen que muestra como Ir a Administrar en Windows 7

2) Luego en la siguiente pantalla Administración de Equipos -> Usuarios y grupos locales -> Allí aparece el listado de los usuarios, si queremos eliminar alguno en particular, le damos clic derecho al usuario deseado y seleccionamos eliminar y dar a la opción ‘’Sí” en el cartel de aviso.

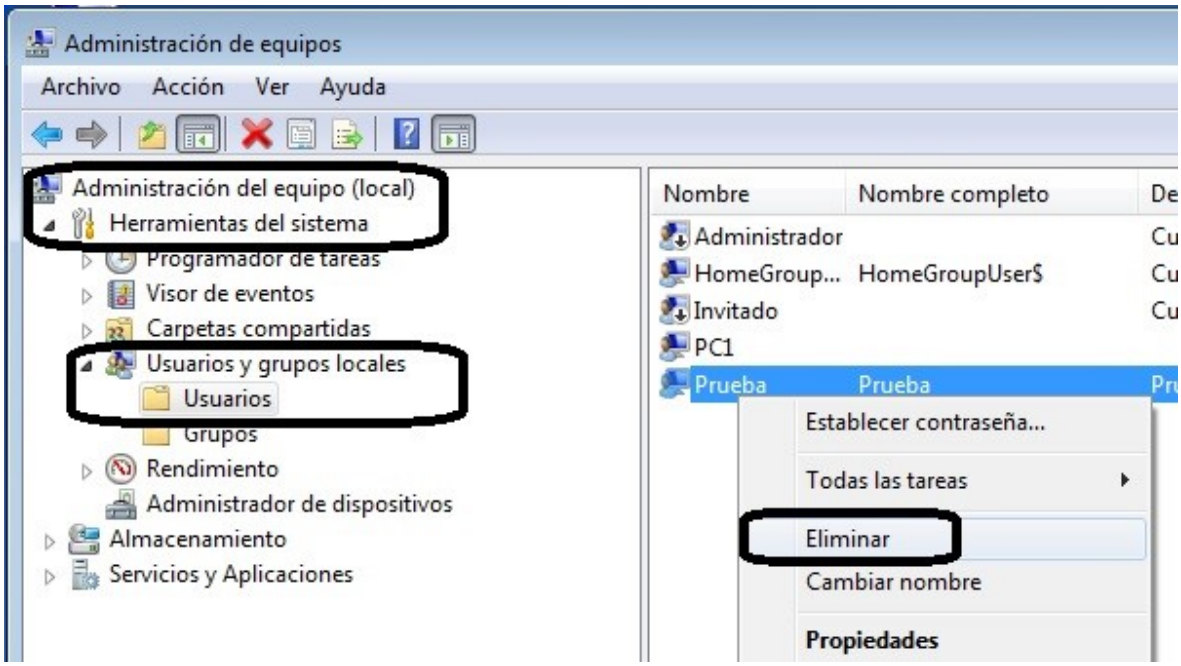

Fig. 2 – Imagen de que muestra como eliminar un usuario, en este ejemplo es PRUEBA

En la opción Propiedades podremos ver podemos deshabilitar la cuenta y otras opciones como se ve en la imagen

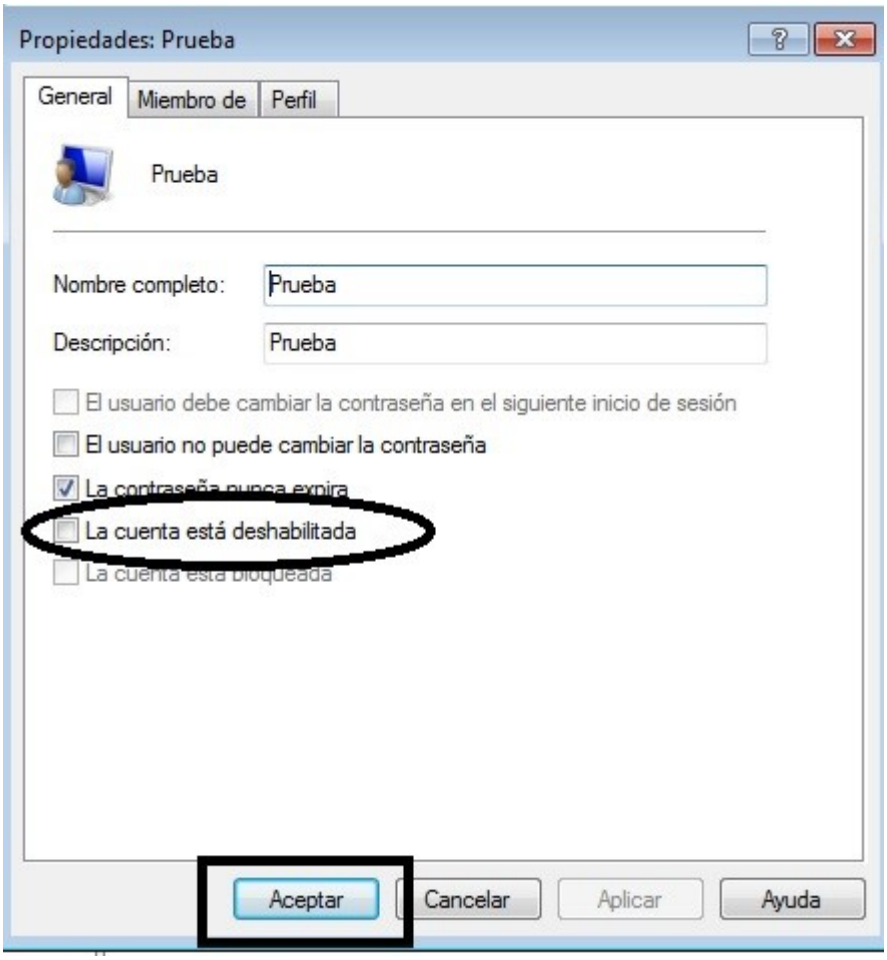

Fig. 3 – Imagen que muestra cómo se puede deshabilitar una cuenta de usuario.

Anexo B

Permisos a usuarios - Carpetas - Archivos - Recursos Compartidos:

Para este proceso se aplica de igual forma para las carpetas, archivos y recursos compartidos como Impresoras.

Cualquiera sea a lo que queremos darle o denegar permisos se realizan los siguientes pasos.

1 Clic derecho -> Propiedades (en este ejemplo se toma la carpeta llamada PEPITO)

-> Solapa Seguridad – Aquí se detalla que usuarios o grupo de usuarios tienen o no permisos -> más abajo se lista el cuadro y tiene los permisos de Control total, Modificar, Lectura y Ejecución, Mostrar el contenido de la carpeta, Lectura y escritura, del margen derecho podemos ver que hay dos columnas, Permitir y Denegar y sobre estas columnas está la opción de habilitar o no según lo que corresponda.

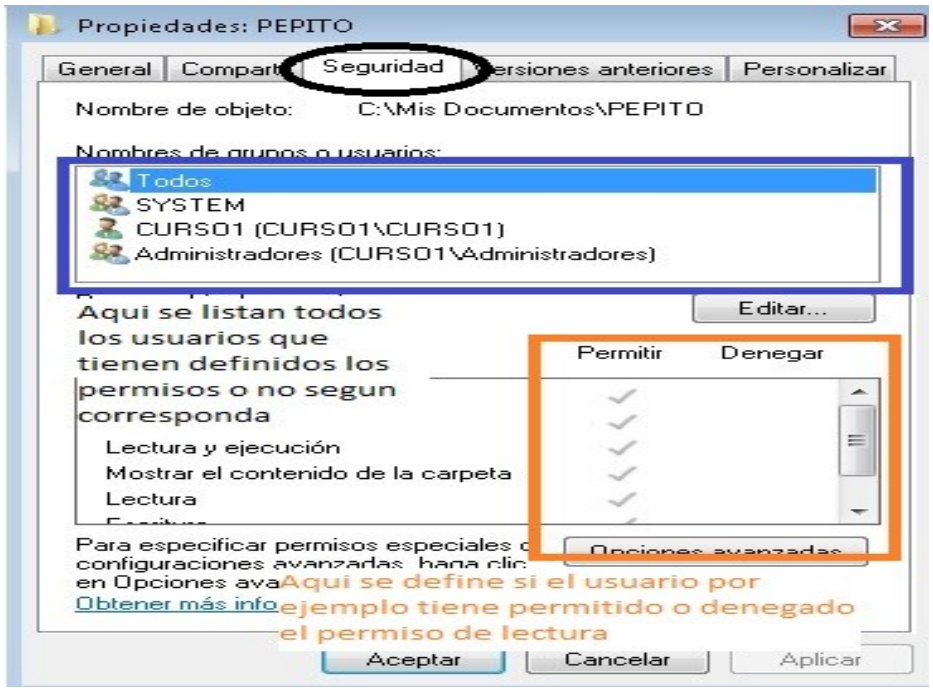

Fig. 4 – Imagen de que muestra la solapa Seguridad de Propiedades de una carpeta y sus opciones

2) Si se realiza un Clic en Editar, podremos agregar o quitar usuarios según corresponda, para agregar, le damos clic y abrirá la pantalla para escribir el nombre del usuario.

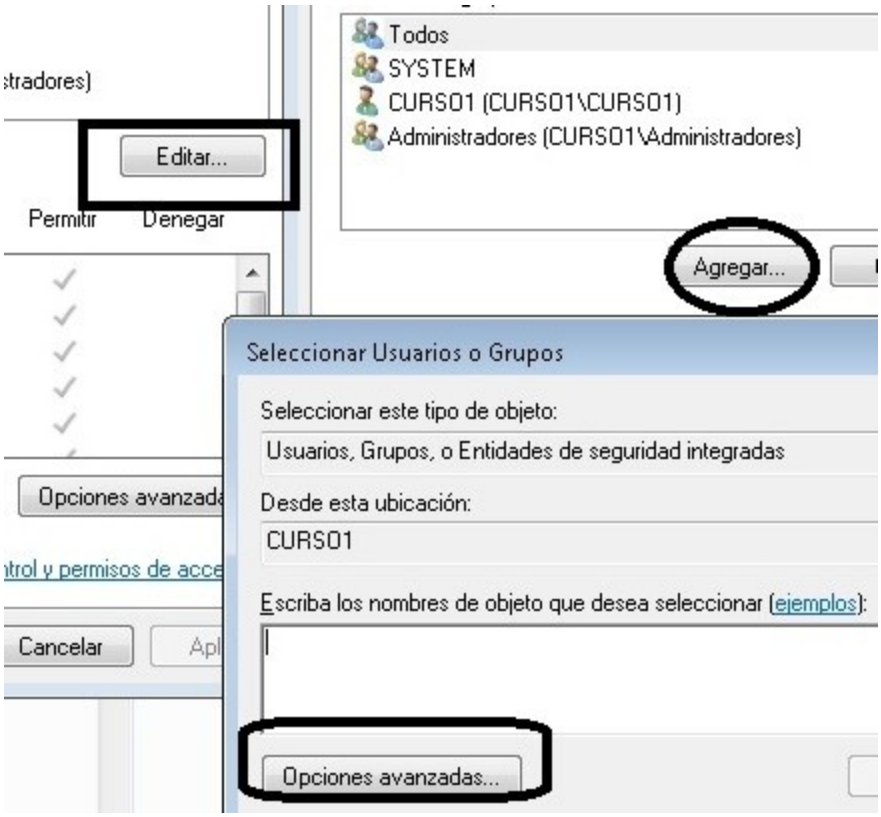

Fig. 5 – Imagen de ejemplo que muestra como agregar usuarios a la solapa seguridad en propiedades de archivos.

O bien, podemos dar clic en Opciones avanzadas y abrirá la siguiente pantalla y en “Buscar ahora” listara todos los usuarios para agregarlos y posteriormente darle o denegar los permisos que se desean.

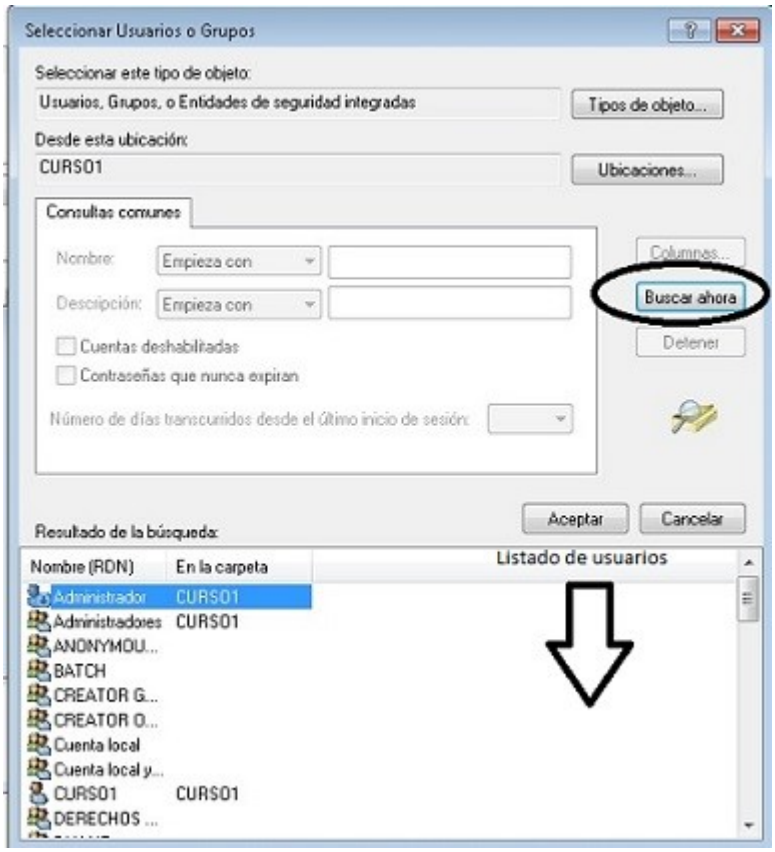

Fig. 6 – Imagen de muestra donde indica cómo podemos buscar los distintos usuarios.

Anexo C

Directivas de seguridad Locales:

1. En la opción Ejecutar, escribimos gpedit.msc y abre las Directivas de seguridad local.
2. Seleccione Directivas de equipo local -> Configuración del equipo/usuario ->Configuración de Windows -> Configuración de seguridad ->Directivas locales->Opciones de seguridad.
3. Haga doble clic sobre Inicio de sesión interactivo: no mostrar el último nombre de usuario y seleccione Habilitada.

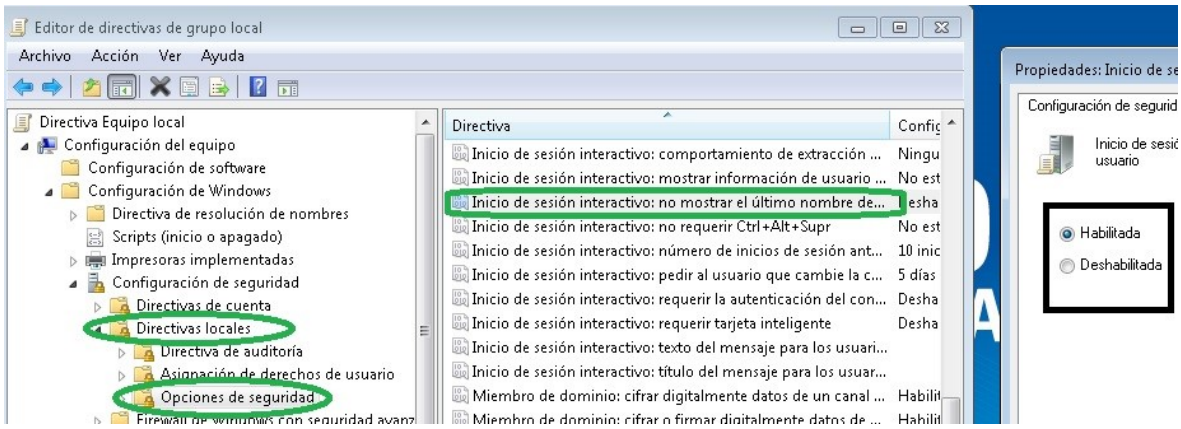

Fig. 7 – Imagen del editor de directivas de seguridad, con un ejemplo.

4. De paso, haga doble clic sobre Cuentas: cambiar el nombre de la cuenta del administrador e introduzca un nombre diferente.

Téngase en cuenta que “Administrador” es uno de los nombres predeterminados más conocidos y blanco prioritario de ataques. De esta manera se mitiga ligeramente el impacto de un ataque sobre esta cuenta todopoderosa. Puede incluso crear una cuenta sin privilegios denominada “Administrador” a modo de cebo. Puede repetir la misma operación para la cuenta de invitado.

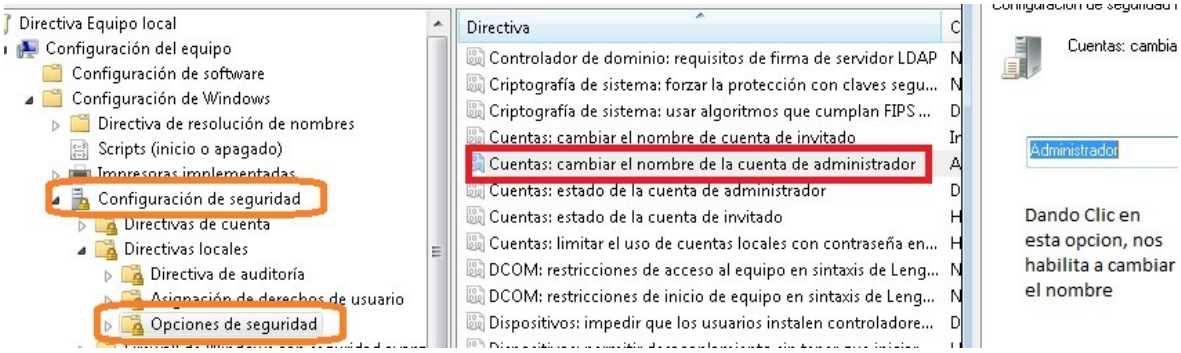

Fig. 8 – Imagen donde se visualiza como cambiar el nombre a la cuenta Administrador

Anexo D

Servicios:

Hay varios caminos para revisar los servicios:

1. Inicio -> Ejecutar -> en el cuadro de búsqueda - Si se realiza en Windows 10 con el buscador que nos propone el Inicio podremos buscarlo “services.msc” sin comillas y nos abrirá el listado correspondiente.
2. Inicio -> Todos los Programas -> Herramientas Administrativas -> Servicios.
3. A partir de Windows 7 tenemos la opción de hacer clic derecho en la barra de Windows -> Administrador de tareas -> Ejecuta el administrador de tareas y esta la solapa Servicios

Para cambiar el estado de un servicio:

Una vez en el listado de servicios llegando por los tres caminos anteriormente mencionados:

Haga doble clic sobre el servicio deseado y seleccione la pestaña General. En función de su estado actual, podrá iniciarlo, detenerlo, pausarlo o reanudarlo.

Si queremos que algunos servicios se ejecuten con una cuenta específica, en las propiedades de cada servicio se encuentra la opción “Iniciar Sesión”, a continuación, seleccionar la opción Cuenta del sistema local si se desea que se ejecute como usuario Sistema local (LocalSystem) o se puede ejecutar como algún otro usuario seleccione la opción “Esta cuenta” y deberemos ingresar las credenciales correspondientes. Al terminar debemos pulsar Aceptar

Por último, a modo de conocimiento, hay algunos servicios que dependen de otros servicios, esto causa que, si se detiene o no funciona correctamente, es posible que otros servicios resulten afectados. Podremos ver en la Solapa Dependencias de las propiedades de cada Servicio y allí se listan en caso que hubiera, otros servicios encadenados.

A modo de ejemplo he hecho algunas capturas a partir de una PC Virtual que contiene Windows 7

1ro) Buscamos la lista de servicios, entonces vamos a Inicio de Windows Ejecutar...

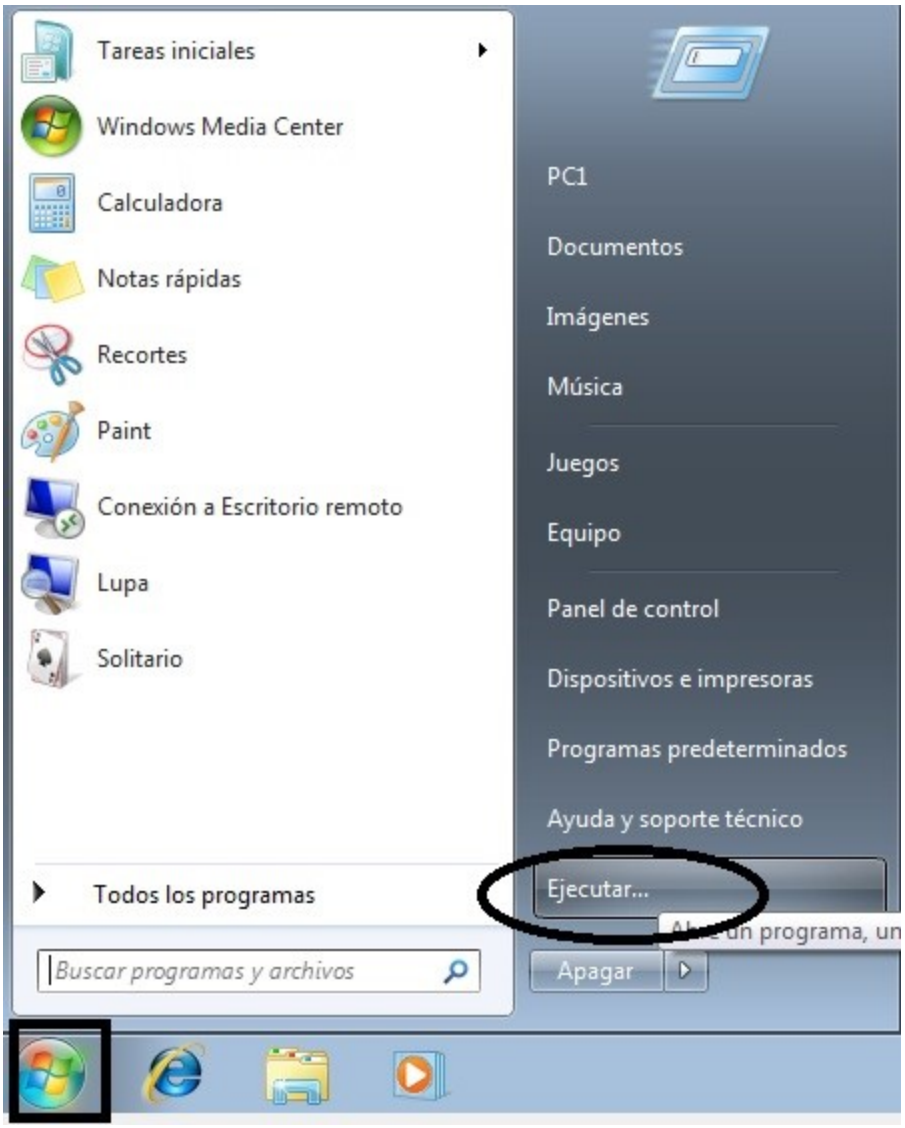

Fig. 9 – Imagen de muestra para ubicar “Ejecutar…” en Windows 7

2do) Buscamos Servicios o como en el ejemplo services.msc y damos Aceptar

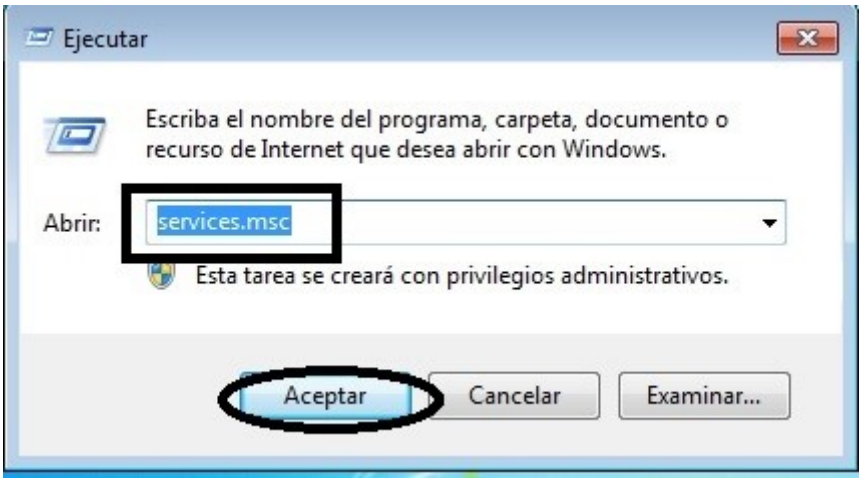

Fig. 10 – Imagen donde se visualiza como ejecutar la ventana de Servicios.

3ro) Nos abre la lista de servicios, seleccionamos el servicio deseado (En este ejemplo usó el Servicio de Windows Update - Sirve para las actualizaciones automáticas de Windows) y le damos clic derecho -> Propiedades

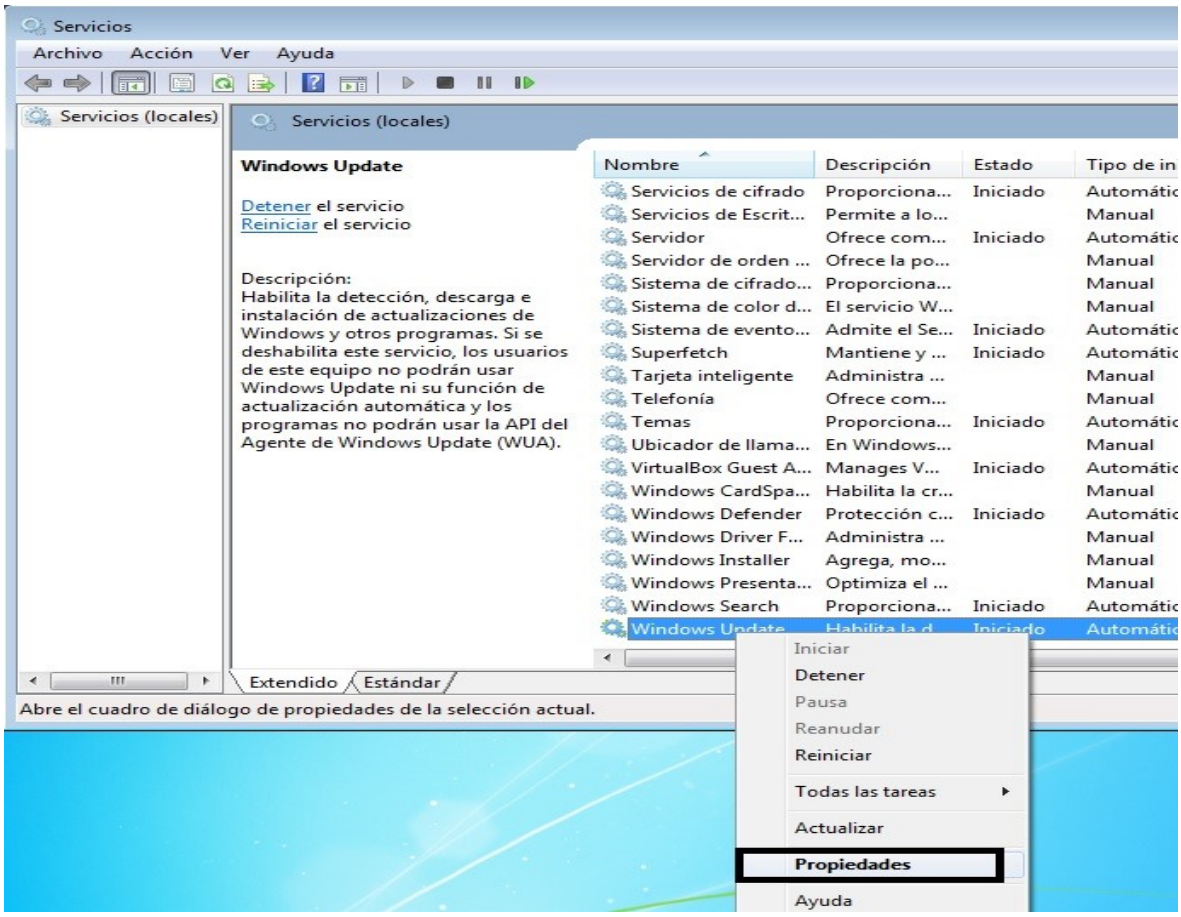

Fig. 11 – Imagen donde se puede visualizar todos los servicios y como acceder a sus propiedades

4to) Estamos en la Solapa General, aquí podremos cambiar el tipo de inicio según muestra la pantalla y según lo descrito anteriormente. Una vez que hayamos decidido debemos presionar el botón Aceptar.

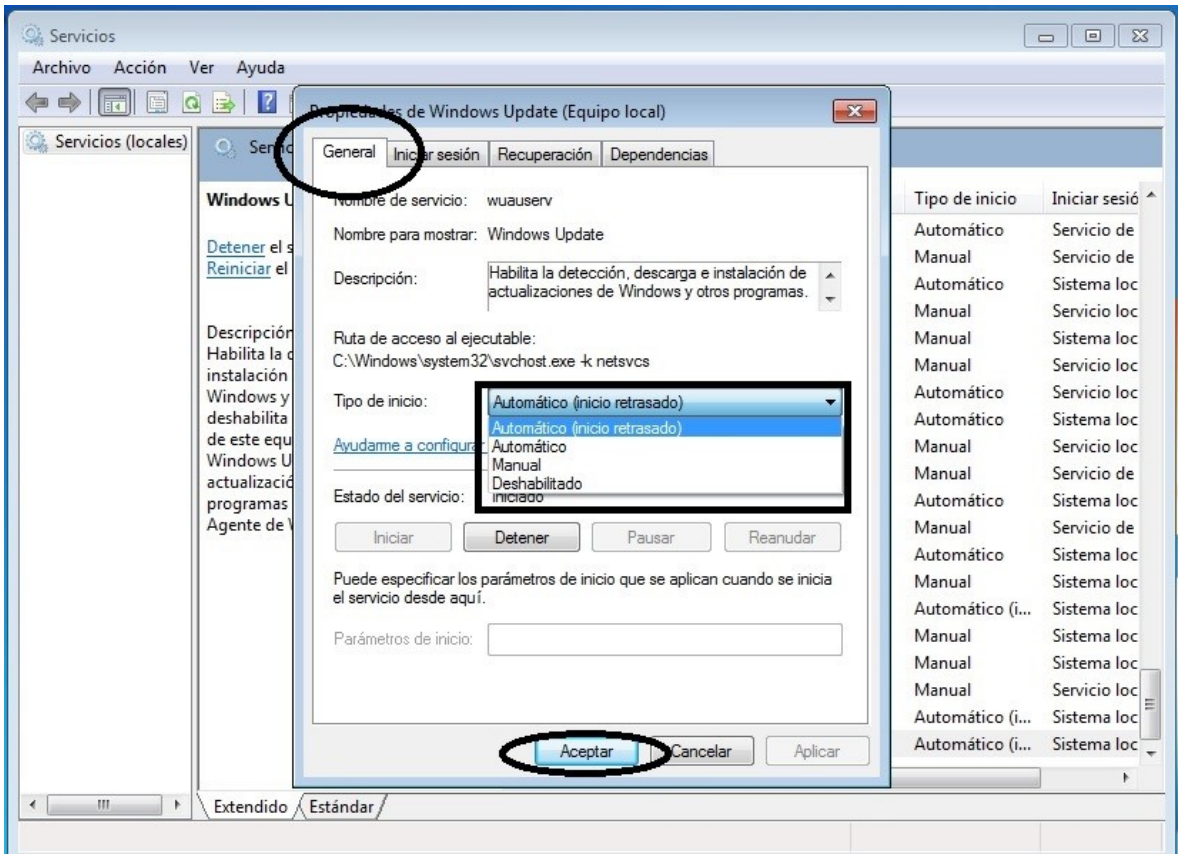

Fig. 12 – Imagen que muestra las distintas opciones de inicio que puede tener un servicio

5to) En la Solapa Iniciar Sesión podremos elegir “Esta Cuenta” y especificar las credenciales con las que queremos que inicie el servicio.

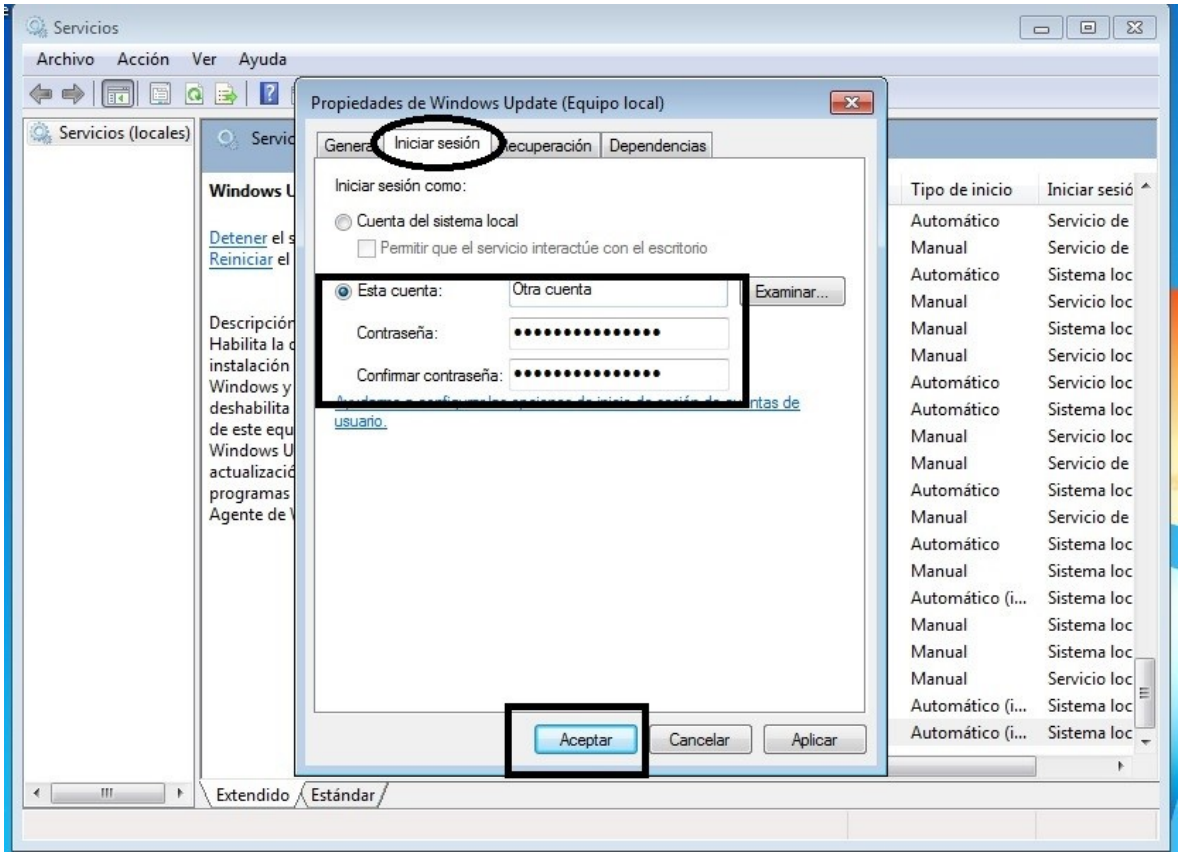

Fig. 13 – Imagen de la solapa Iniciar Sesión en propiedades de servicio, es donde podemos indicar alguna otra cuenta para que inicie el servicio.

6to) En la Solapa Dependencias podemos ver en el recuadro azul indica que servicios dependen, en este caso, de Windows Update. En el recuadro rojo indica que servicios son necesarios para que Windows Update se inicie.

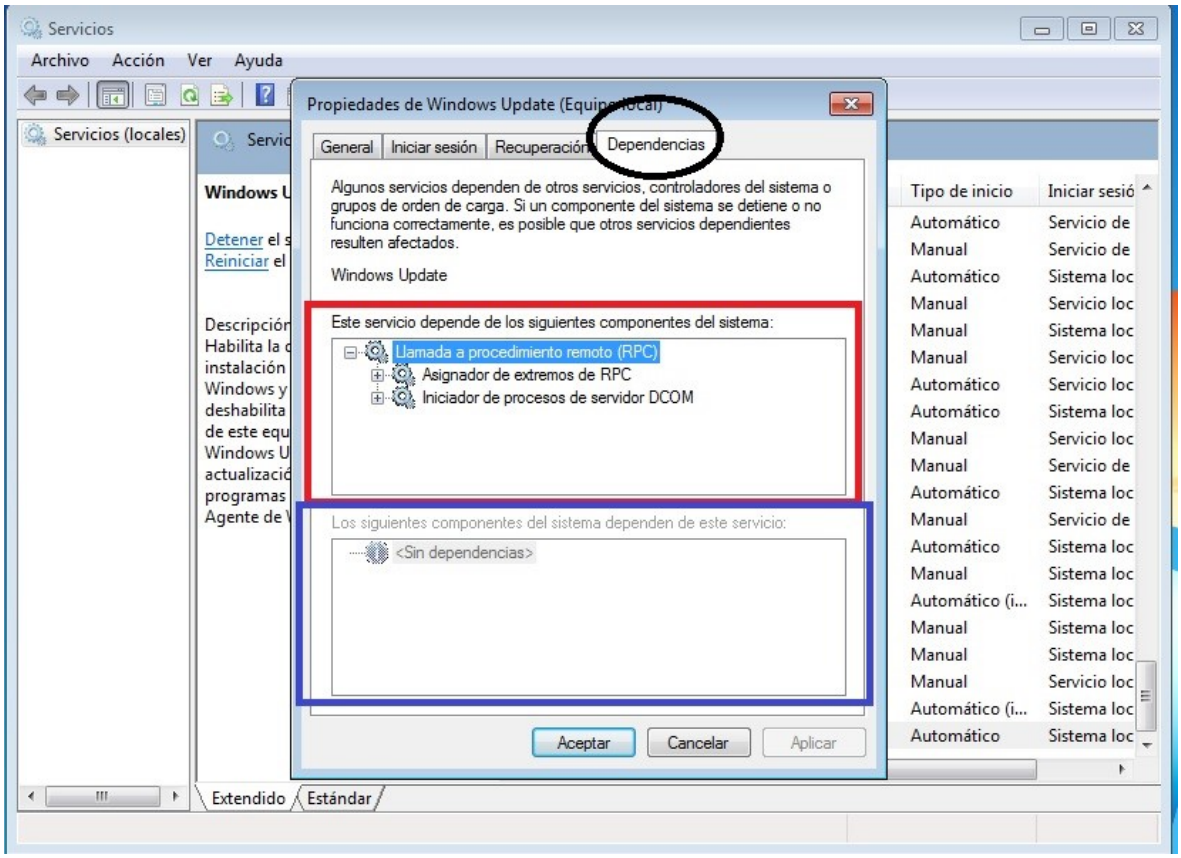

Fig. 14 – Imagen de la solapa Dependencias donde indica si un servicio depende de otro u otros servicios dependen del servicio.

Anexo E

Ejecución de programas como usuario Administrador/Otro Usuario:

Haciendo clic sobre el nombre del programa con el botón secundario del ratón y seleccione Ejecutar como. Seleccione la opción El siguiente usuario e introduzca las credenciales del nuevo usuario. - A partir de Windows 7 está la posibilidad de Ejecutar Como Administrador.
A continuación, se muestran los pasos en imágenes (Se tomó una virtual con Windows XP para este propósito)

Fig. 15 – Imagen de ejecutar como Administrador en Windows XP.

Aquí se toma como ejemplo el acceso directo de cualquier programa, clic derecho y esta la opción marcada de “Ejecutar como…”

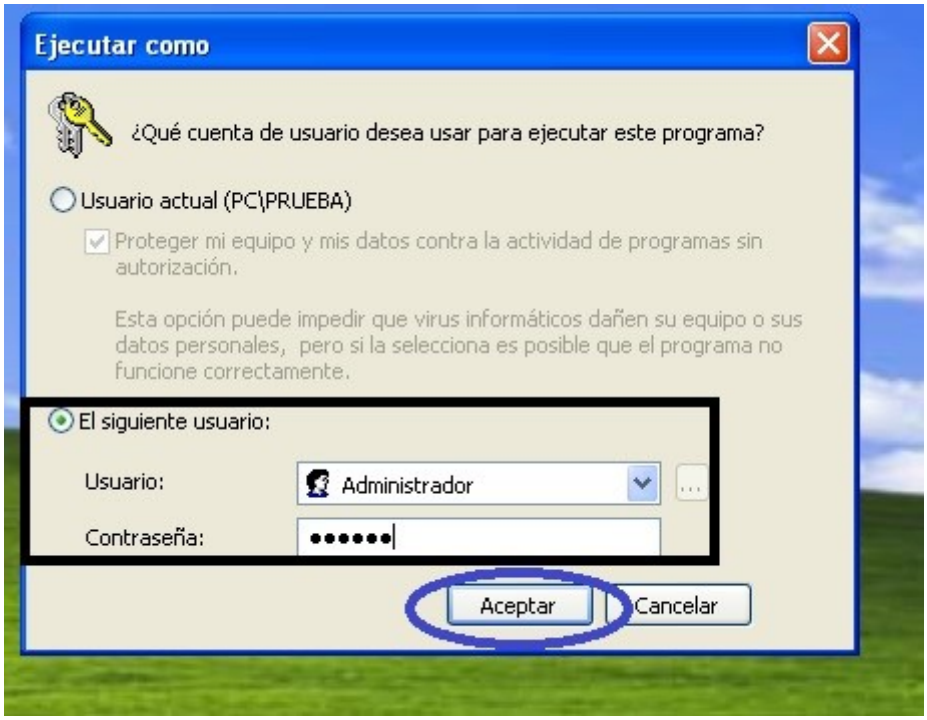

Fig. 16 – Imagen que indica que al ejecutar como administrador hay que ingresar las credenciales.

Luego abrirá esta pantalla la cual podemos seleccionar qué usuario vamos a utilizar y luego poniendo la contraseña y aceptar, así ejecutaremos el programa con dicho usuario. En este ejemplo, si pusiéramos la contraseña correcta de administrador y le damos aceptar, ejecuta el sistema con la cuenta usuario Administrador.

A partir de Windows 7 los pasos son más abreviados. Solo con dar clic derecho en el programa deseado -> Ejecutar como Administrador como se muestra en la siguiente imagen

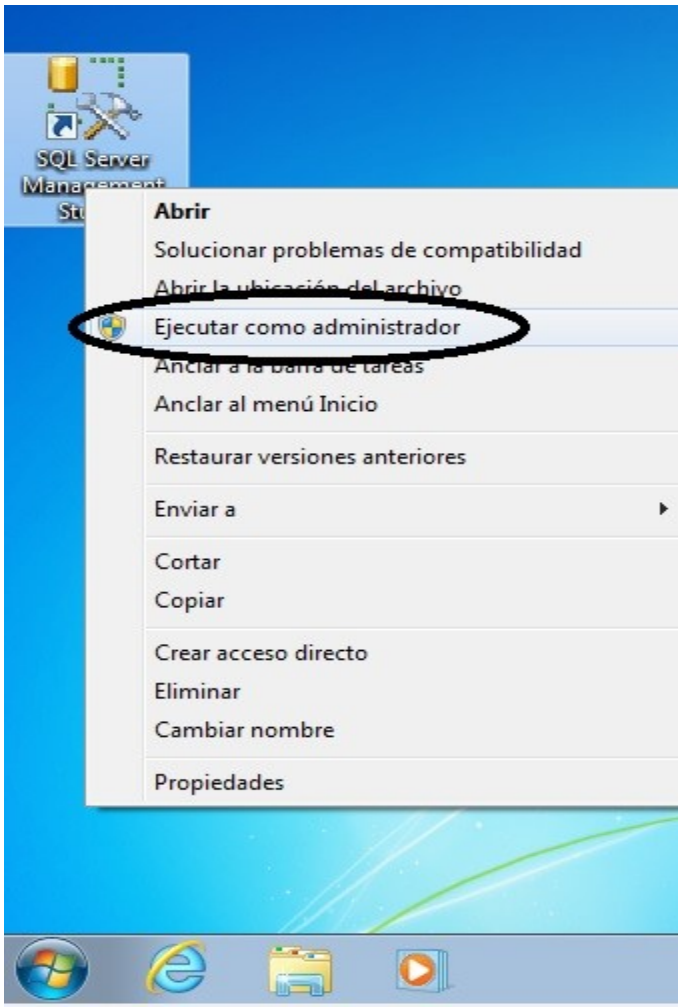

Fig. 17 – Imagen de como Ejecutar como Administrador en Windows 7 (aplica igual a las siguientes versiones)

Si se hace clic sobre su acceso directo con el botón secundario del ratón y selecciona Propiedades. A continuación, pulse el botón Propiedades avanzadas y verifique la casilla Ejecutar con credenciales diferentes, como muestra en la siguiente imagen (aplica para todas las versiones de Windows).

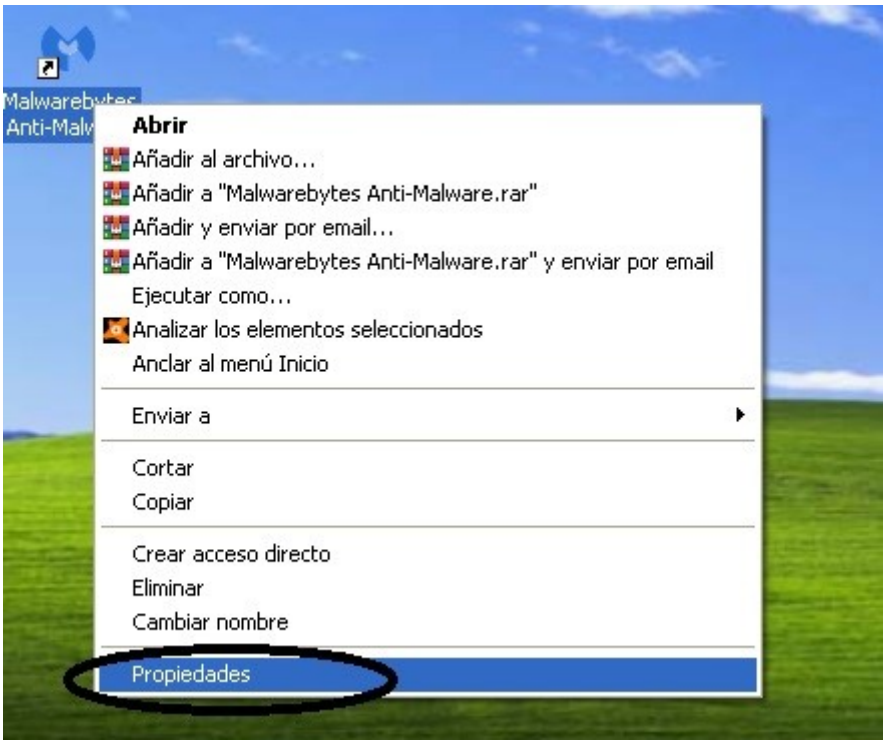

Fig. 18 – Imagen que muestra como ver las propiedades de un programa para posteriormente ejecutarlo con otras credenciales.

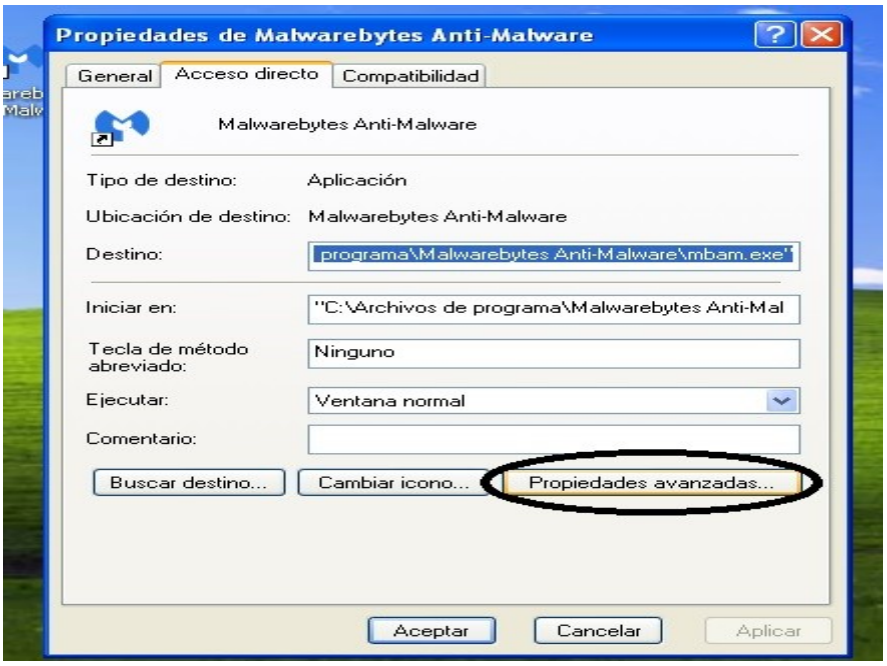

Fig. 18.1 – Imagen que muestra como ver las propiedades avanzadas de un programa para posteriormente ejecutarlo con otras credenciales.

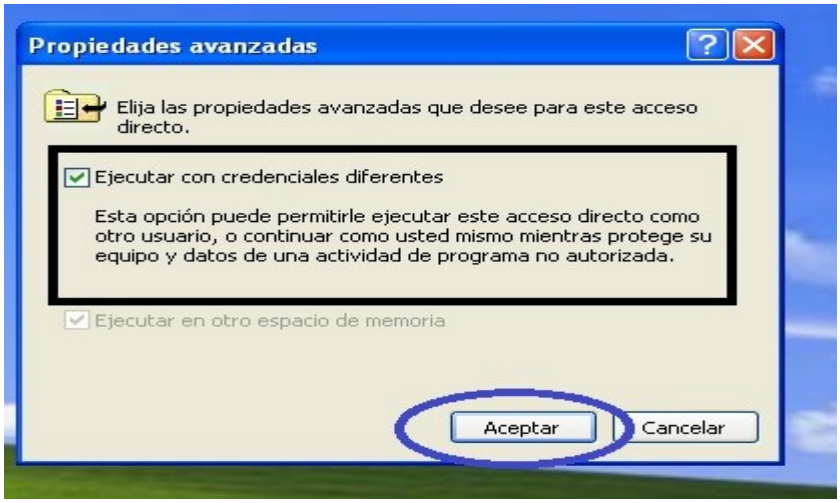

Fig. 18.2 – Imagen que muestra como indicar que un programa se ejecute con credenciales diferentes.

Al darle aceptar a esta pantalla cada vez que ejecutemos el programa nos pedirá las credenciales con el usuario que deseamos iniciar dicho programa.

Capítulo VIII - Bibliografía

1. "Computer Recreations: Of Worms, Viruses and Core War", Scientific American, March 1989, p. 110.
2. Gonzalo Alvarez Marañon y Pedro Pablo Perez Garcia - Seguridad Informática para empresas y particulares - Páginas 25, 83, 93, 146, 165, 237, 342, 350, 352 - ISBN:84-481-4008-7 - Año: 2004
3. Carlos S. Tori - Hacking Ético - Capítulo 2, Capítulo 3, Capítulo 7 - Recabar Información - Año 2008 - ISBN: 978-987-05-4364-0
4. Alvaro Gomez Vieltes - Enciclopedia de la Seguridad Informática. 2ª Edición - Páginas 47, 62, 71, 123, 195, 297, 327 - Año 2011 - ISBN 9786077071815
5. Estudiante de Escuela Politécnica del ejercito - Hardening Microsoft Windows - Páginas 62, 76, 93, Año: 2010 - https://repositorio.espe.edu.ec/bitstream/21000/316/1/T-ESPE-029758.pdf
6. Alejandro Corletti - Seguridad por Niveles - Páginas 59, 77, 135, 484, 566 - RPI (MADRID) 03/119554.9/11 Año: noviembre 2011
7. Alejandro Corletti - Ciberseguridad Una estrategia Informático/Militar - Página 27 - ISBN: 978-84-697-7205-8 Año: noviembre 2017
8. Sergio Talens Oliag - Articulo “Seguridad Física” - https://www.uv.es/sto/cursos/icssu/html/ar01s04.html
9. Darli Briceño-Yugledys Quintero - Articulo “Seguridad Física en el área de Informática” - https://seguridadfi.blogspot.com/2015/10/seguridad-fisica-en-el-area-de.html - Año 2015
10. Autor No encontrado- Articulo - Política seguridad física sisteseg Bogotá Colombia - https://sisteseg.com/files/Microsoft_Word_-_Politica_Seguridad_Fisica.pdf
11. Autor No encontrado - Articulo - Seguridad física de los sistemas - https://www.rediris.es/cert/doc/unixsec/node7.html
12. José María López Hernández - Seguridad Física COMO - Página 12 y 32 - Seguridad Física COMO es un tutorial dedicado a la Seguridad Física de Sistemas - http://es.tldp.org/Manuales-LuCAS/doc-como-seguridad-fisica/COMO-seguridad-fisica.pdf
13. Estadística de sistemas operativos - https://netmarketshare.com

14. Marcelo Bugallo - Articulo - PyMEs, las más afectadas por los ciberataques - Año 2019 https://m.perfil.com/noticias/opinion/opinion-marcelo-bugallo-PyMEs-las-mas-afectadas-por-los-ciberataques.phtml?rd=1
15. FRANCISCO JAVIER RUIZ - Articulo - ¿Cómo se ven las PyMEs ante los Ciberataques? - Año 2019 - https://blog.dataprius.com/index.php/2019/07/26/66-porciento-PyMEs-no-se-ven-vulnerables-a-ciberataque/
16. AFIP - Página Oficial - ¿Que es una PyME? - https://PyMEs.afip.gob.ar/estiloAFIP/PyMEs/ayuda/default.asp
17. ESET - Camilo Gutiérrez Amaya - Articulo - Como clasificar la información corporativa - https://www.welivesecurity.com/la-es/2012/11/27/como-clasificar-informacion-corporativa/ Año: 2012
18. Autor - Informática ZARAGOZA ARATECNIA - Articulo - Medidas de seguridad Informática que deben tener las empresas - http://www.aratecnia.es/medidas-de-seguridad-Informática/
19. Reporte de Seguridad ESET Año 2018 - Articulo - https://empresas.eset-la.com/archivos/novedades/69/ESET_security_report_LATAM2018-final.pdf
20. ESET - Stephen Cobb - Articulo - Guía de Ciberseguridad para Pymes - https://empresas.eset-la.com/novedad/guia-de-ciberseguridad-para-pymes
21. Rubén Velasco - Articulo - Los activadores para Windows y sus peligros- https://www.redeszone.net/2015/08/01/los-activadores-para-windows-y-sus-peligros/ - Año 2015.
22. Andrés Garavaglia – Filminas pertenecientes a la cursada de Seguridad Y Privacidad – UCALP 2017